ISEP INSTITUTO SUPERIOR DE ENGENHARIA DO PORTO

Mestrado em Engenharia Informática – Cibersegurança e Administração de Sistemas.

ASSIGNMENT 1 - TRAFFIC ANALYSIS

SEGSI

1260541 Luís Sá
1260513 André Ribeiro
1131504 Joana Soares

22/10/2026
Instituto Superior de Engenharia do Porto

Contents

1 Introduction 7

2 Methodology 8

2.1 Wireshark 8

2.2 Analysis methodology 9

3 Capture methodology 11

3.1 Capture nº.1 11

3.1.1 Overview 11

3.1.2 Intervenients 11

3.1.3 Main Protocol 12

3.1.4 Communication Analysis 12

3.1.5 LDAP Operations Analysis 12

3.1.5.1 Simple Bind Authentication 12

3.1.5.2 Bind Result 13

3.1.5.3 Root Directory Search 14

3.1.5.4 Directory Structure Enumeration 14

3.1.5.5 User Enumeration 15

3.1.6 Security Analysis 15

3.1.6.1 Vulnerability 1 - Plaintext credentials 15

3.1.6.2 Vulnerability 2 - Unencrypted LDAP communication 16

3.1.6.3 Vulnerability 3 - Directory information disclosure 16

3.1.6.4 Vulnerability 4 - User enumeration 16

3.1.6.5 Vulnerability 5 - Infrastructure disclosure 16

3.1.7 Mitigation 16

3.1.8 Conclusion 17

3.2 Capture nº.2 18

3.2.1 Overview 18

3.2.2 Intervenients 18

3.2.3 Main Protocol 19

3.2.4 Communication Analysis 19

3.2.5 Follow Stream Analysis 20

3.2.5.1 Authentication 20

3.2.5.2 Mailbox Information 20

3.2.5.3 Email Retrieval 21

3.2.5.4 Message Deletion 21

3.2.6 Security Analysis 21

3.2.6.1 Vulnerability 1 - Plaintext credentials 21

3.2.6.2 Vulnerability 2 - Weak Password 22

3.2.6.3 Vulnerability 3 - Email confidentiality 22

3.2.6.4 Vulnerability 4 - Mailbox activity disclosure 22

3.2.6.5 Vulnerability 5 - Service fingerprinting 22

3.2.7 Mitigation 22

3.2.8 Conclusion 23

3.3 Capture nº.3 24

3.3.1 Overview 24

3.3.2 Intervenients 24

3.3.3 Main Protocol 25

3.3.4 Communication Analysis 25

3.3.5 Follow Stream Analysis 25

3.3.5.1 Authentication 25

3.3.5.2 Directory Listing 26

3.3.5.3 Transfer of logagent.exe 27

3.3.5.4 Transfer of mplayer2.exe 27

3.3.5.5 XPWD 28

3.3.6 Security Analysis 28

3.3.6.1 Vulnerability 1 - Plaintext credentials 28

3.3.6.2 Vulnerability 2 - Weak Password 28

3.3.6.3 Vulnerability 3 - Privileged account 28

3.3.6.4 Vulnerability 4 - File-transfer confidentiality 29

3.3.6.5 Vulnerability 5 - Service fingerprinting 29

3.3.7 Mitigation 29

3.3.8 Conclusion 29

3.4 Capture nº.4 31

3.4.1 Overview 31

3.4.2 Intervenients 31

3.4.3 Main Protocol 31

3.4.4 Communication Analysis 31

3.4.5 Security Analysis 33

3.4.6 Mitigation 34

3.4.7 Conclusion 34

3.5 Capture nº. 5 35

3.5.1 Overview 35

3.5.2 Intervenients 35

3.5.3 Screenshot 1 36

3.5.4 Main Protocol 36

3.5.5 Performed Operations 37

3.5.5.1 Access-Request 37

3.5.5.2 Access-Accept 37

3.5.6 Screenshot 2 38

3.5.7 Communication Analysis 39

3.5.7.1 Communication Sequence 39

3.5.7.2 Relationship with authentication, authorization and accounting (AAA) 39

3.5.8 Security Analysis 39

3.5.8.1 Vulnerability 1 - Information Disclosure 39

3.5.8.2 Vulnerability 2 - MS-CHAP exposure 40

3.5.8.3 Vulnerability 3 - Legacy cryptographic mechanism 40
3.5.9 Mitigation 41
3.5.10 Conclusion 41
3.6 Capture nº.6 42
3.6.1 Overview 42
3.6.2 Intervenients 42
3.6.3 Main Protocol 42
3.6.4 Communication Analysis 42
3.6.5 Security Analysis 44
3.6.6 Mitigation 45
3.6.7 Conclusion 45
4 PL02.ex1 - Active Directory and Kerberos 46
4.1 Introduction and background 46
4.1.1 Active Directory and access control 46
4.1.2 Kerberos in the domain 46
4.1.3 Analysis method 46
4.2 Laboratory environment 47
4.2.1 System updates 47
4.3 Server network configuration 48
4.4 Communication with the Linux workstation 49
4.5 Directory service installation 50
4.6 Forest and domain creation 51
4.7 Domain controller validation 52
4.8 Environment generation with BadBlood 53
Changes in domain object counts 55
4.9 Data collection with SharpHound 56
4.10 Running BloodHound Community Edition 58
4.11 Neo4j configuration and access 59

4.12 Data import and exploration 60

4.13 Domain properties in BloodHound 61

4.14 Administrator account memberships 62

4.15 Privilege path to DC01 63

4.16 Scope of the Domain Admins group 64

4.17 Attack vector analysis 65

4.17.1 Observed path and starting condition 65

4.17.2 Potential exploitation in a test environment 65

4.17.3 Relationship with Kerberos 65

4.17.4 Evidence required to complete validation 65

4.18 Risks and mitigation measures 66

4.19 Results against the exercise requirements 67

4.19.1 Experimental limitations 67

4.20 Conclusion 68

4.20.1 Summary of confirmed results 68

5 PL03.ex1 - TACACS+ 69

5.1 Objective 69

5.2 Server installation and preparation 69

5.3 TACACS+ configuration 70

5.4 Linux system users and groups 70

5.5 Authentication test and traffic capture 70

5.6 TACACS+ packet analysis 71

5.7 Extraction and recovery of the shared secret 72

5.8 Security considerations 72

5.9 Summary 73

6 PL04.ex1 - Discretionary Access Control Lists (DACLs) 74

6.1 Objective 74

6.2 Service Desk – Finance Password Reset 75

6.3 SysAdmin – Management of Domain Admins Membership 76

6.4 HR – Write Personal Information 77

6.5 SysAdmin – Group Membership Management 78

6.6 Limitations of DACL Management at Scale 79

6.7 Additional Security Controls 80

6.8 Excluding One User from a Group Permission 81

6.9 Summary 81

7 Conclusions 83

8 References 84

1 Introduction

Network and system security is crucial for protection of information, service and user from any type of threat. It is important to know how network protocols function and access rights are handled.

This paper contains the practical work performed within the Systems and Network Security Management (SEGSI) course. The assignment includes analysis of network protocol traffic with the use of Wireshark as well as system security and access control exercises.

The analysis will include investigation of protocol used, evaluation of systems' communication and potential security threats. Exercises will be dedicated to the configuration of security features, including the management of permissions and administration delegation within the Active Directory.

The key goal is to demonstrate knowledge gained during the course and analyze the security mechanisms used in real world.

2 Methodology

This assignment has adopted a practical approach where there is a combination of network traffic analysis and security principles learned in SEGSI practical laboratories.

The first part involved analyzing the packets provided in order to know the systems in use, the protocols and operations carried out together with the security considerations. Each packet was analyzed individually in a consistent manner.

The second part was carried out practically through various lab exercises involving system security and access control. This was done in a controlled environment. Screenshots were taken during the process of carrying out the experiment and the configurations documented. In particular, the individual exercise involved discretionary access control lists (DACL) in Microsoft Active Directory.

The conclusions in the report are based on the observations drawn from the analysis of packets. Where the packet did not give enough information to draw a particular conclusion, it was avoided to make an assumption.

2.1 Wireshark

The first tool used to perform the network packet analysis was Wireshark. The program enabled examining the captured data on various protocol stack layers and studying individual packets.

For each capture file, the first stage of the analysis was done by performing an inspection of the packet list in order to find out what protocols were used, the source and destination addresses, the transport protocols, and ports. If necessary, the Wireshark filters were used to narrow down the traffic and study only that which relates to the chosen protocol.

The packet details pane was used to examine specific attributes of protocols. This stage is especially important for RADIUS analysis since attributes such as RADIUS Message Type, User-Name, Service-Type, NAS Information, and Microsoft-specific Vendor Attributes are studied.

For connection-oriented protocols, the communication was also studied in its entirety instead of only as packets. Where possible, the follow TCP stream feature of Wireshark was utilised to determine application-level transactions. This allowed the analysis of the authentication process and further FTP commands in the FTP capture.

A series of screenshots was taken using Wireshark to provide evidence in support of the findings of the report. However, the screenshots provided evidence related to the topic at hand and were not for all packets in the capture.

2.2 Analysis methodology

The same analysis methodology was used to study the packet captures. The aim of this procedure was to shift from the identification of the communication to its technical understanding and, ultimately, to security implications of that communication.

The following steps were done during the analysis:

1. Initial examination of the capture – The capture was reviewed to get information about its size, main protocols used and basic communication characteristics.

2. Identification of participants – The IP addresses, ports and system identifiers of both the source and destination hosts were reviewed to find out their roles (client, server, NAS and so forth).

3. Protocol identification – The main application and transport layer protocols were identified. Then, relevant protocol characteristics, messages, ports and communication methods were examined.

4. Reconstruction of the communication – Packets of the same communication were analyzed chronologically to understand what actions were performed. If needed, Wireshark stream analysis was used for analyzing full application-layer exchanges.

5. Collection of evidence – Relevant packets' fields, commands, responses and other protocol parameters were identified. Screenshot samples were included in case they were directly related to the findings presented in the report.

6. Security analysis — The observable behavior was analyzed in terms of security by looking into various factors like authentication, authorization, confidentiality, information disclosure, encryption methods, privilege management and information about infrastructure being exposed.

7. Mitigation analysis — Each of the issues discovered was then subjected to an analysis of what could be done in order to mitigate the risks. This involved things like better forms of authentication, encryption of communication channel, network segmentation, principle of least privilege, better credential policies, etc. depending on the characteristics of each scenario.

Particular care has been taken not to confuse observable evidence with inference. For instance, in the FTP analysis, the evidence clearly shows how the authentication details could be recovered and that the credentials are accepted by the server. It also provides the names of the executables that have been transferred over FTP. However, the packet capture does not prove the maliciousness of those executables.

Similarly, the RADIUS capture was analyzed on the basis of the data available in the packets. In the capture, the username, NAS information, and MS-CHAP challenge-response data is exposed, although not the user's password in plaintext form.

With respect to the practical access control task, the methodology for this task involved implementation of the necessary permissions in Microsoft Active Directory and testing of the resulting behavior through test accounts. DACLs were used to delegate particular administrative tasks to the Service Desk, HR and SysAdmin groups without granting unnecessary privileges. For the practical validation, aspects such as password management, modification of employee data and group membership were taken into consideration.

Also, the principle of least privilege, effective permissions, inheritance and potential security impact of the delegation of the relevant tasks were analyzed with respect to DACLs. Along with the implemented configuration, scalability, auditing, monitoring and access review were also taken into account.

All in all, the methodology described above was designed to ensure the reproducibility of the conclusions made within the assignment and their theoretical justification.

3 Capture methodology

3.1 Capture nº.1

3.1.1 Overview

Capture 1 illustrates the LDAP session established between the client at 192.168.170.130 and the directory server at 192.168.170.132. The session is conducted using the TCP port 389, which involves an LDAP Simple Bind followed by some directory searches.

The client authenticates itself as CN=Bob B. Munchies,CN=Users,DC=segsi_domain,DC=local. The authentication process is successful after which the client asks for directory root, schema, and domain information and gets details about the directory containers and the user objects.

The most important security problem is that the LDAP session is not secured with TLS. In particular, the Bind Request contains the password in plaintext while other LDAP Responses reveal directory and account information.

Property	Observed value
Main protocol	LDAP
Transport protocol	TCP
Client	192.168.170.130
Server	192.168.170.132
Server port	TCP/389
Bind identity	CN=Bob B. Munchies,CN=Users,DC=segsi_domain,DC=local
Authentication result	Successful

3.1.2 Intervenients

Two hosts take part in the captured LDAP interaction.

LDAP Client - 192.168.170.130

This host initiates TCP connections with the LDAP server and submits the Bind Request as well as Search Requests. For authentication purposes, it uses the distinguished name CN=Bob B. Munchies,CN=Users,DC=segsi_domain,DC=local.

LDAP Server - 192.168.170.132

This host waits for connections from the client via TCP port 389 and responds to its authentication request and search requests.

3.1.3 Main Protocol

The application layer protocol being used in this capture is Lightweight Directory Access Protocol (LDAP). This protocol is often used for accessing and managing directory information such as objects like users, groups, computers, configuration containers and schema information.

In this case, LDAP operates directly on TCP port 389. While port 389 may be secured through StartTLS, there is no TLS in the current packet capture, and the Bind credentials are readable in the packet contents. Hence, this LDAP traffic is not encrypted.

3.1.4 Communication Analysis

First, a TCP connection is established by the client with 192.168.170.132:389. Then it issues an LDAP Simple Bind Request, which includes the user distinguished name. The server answers with a Bind Response whose resultCode is success (0).

After authenticating, the client makes several LDAP Search Requests, fetching root directory data, configuration/schema information, domain containers, and actual directory objects. Thus, this session includes both authentication attempts and directory enumeration attempts.

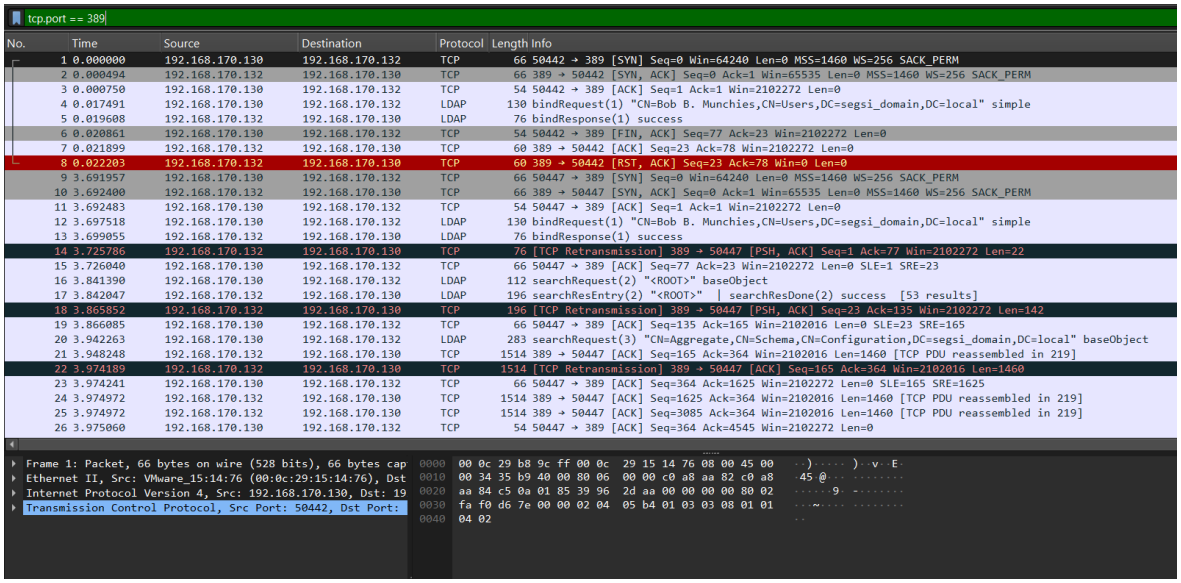


Figure 1 - Wireshark capture 1 showing LDAP communication between 192.168.170.130 and 192.168.170.132

3.1.5 LDAP Operations Analysis

3.1.5.1 Simple Bind Authentication

The Simple Bind is used by the LDAP client for authentication. The user identification is made possible via the Bind Request through the distinguished name:

CN=Bob B. Munchies,CN=Users,DC=segsi_domain,DC=local

At the same time, the value of authentication is exposed since there is no use of TLS to secure the session. It can be seen on Wireshark as:

!QA22zwsx

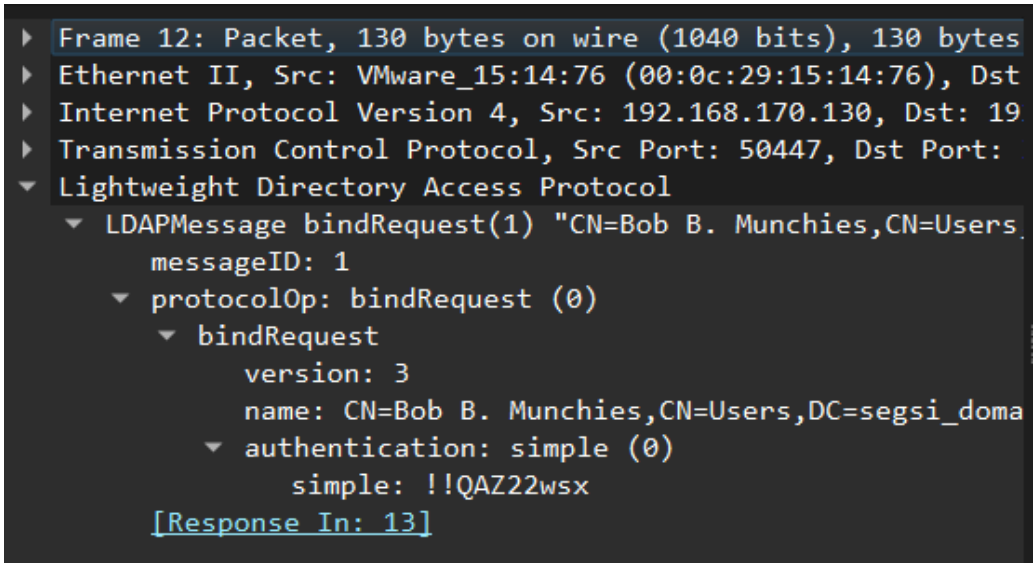


Figure 2 - LDAP Simple Bind request exposing the user distinguished name and authentication secret

3.1.5.2 Bind Result

The response from the server to the Bind Request is the LDAP Bind Response. In this case, the result code indicates success (0). This is evident through the Wireshark capture where the response is correlated to frame 12.

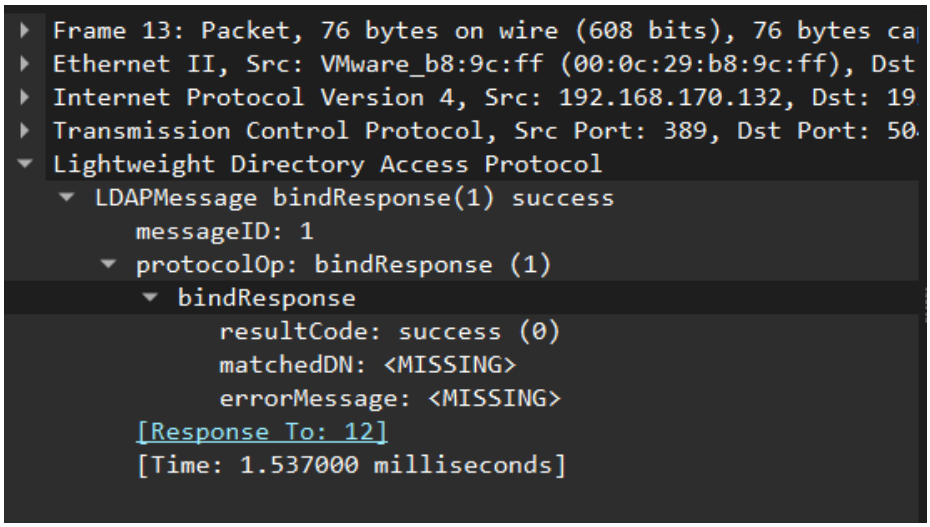


Figure 3 - LDAP Bind Response confirming successful authentication

3.1.5.3 Root Directory Search

The client then executes a search query on the LDAP root object after authentication. This search is based on baseObject scope and a filter (objectClass=*).

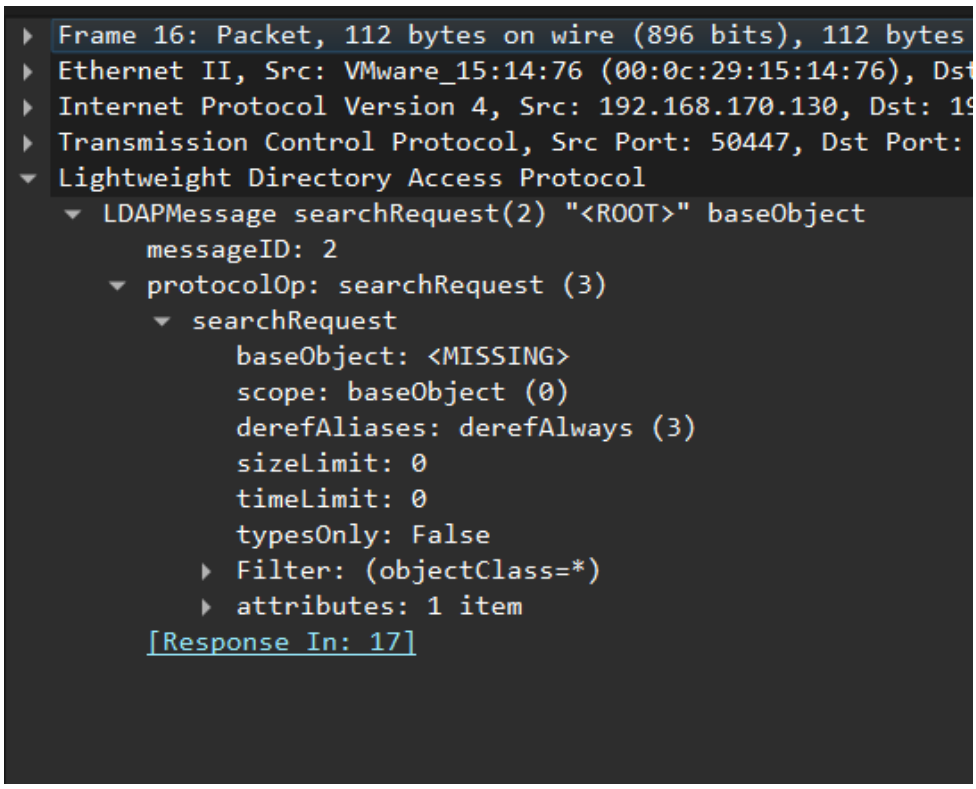


Figure 4 - LDAP Search Request for the directory root object

3.1.5.4 Directory Structure Enumeration

LDAP provides information in search result entry replies. A search result entry reply discloses the schema configuration path CN=Aggregate,CN=Schema,CN=Configuration,DC=segsi_domain,DC=local.

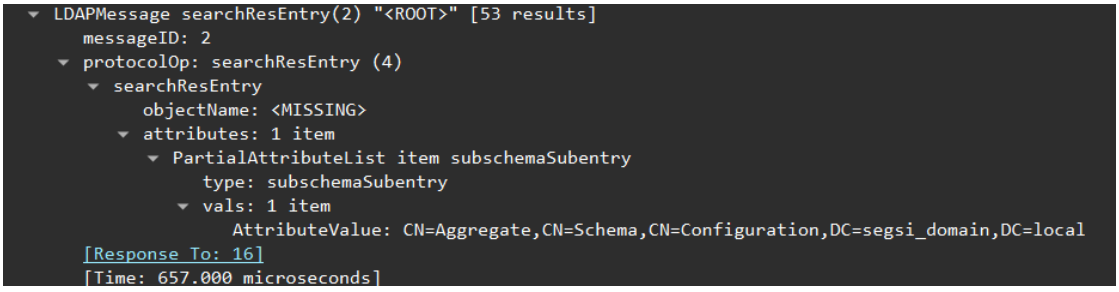


Figure 5 - LDAP Search Result exposing schema and configuration information

A further reaction identifies the domain DC=segsi_domain,DC=local and mentions the use of ForestDnsZones, DomainDnsZones and the Configuration container. The above values help to understand how the directory is structured internally.

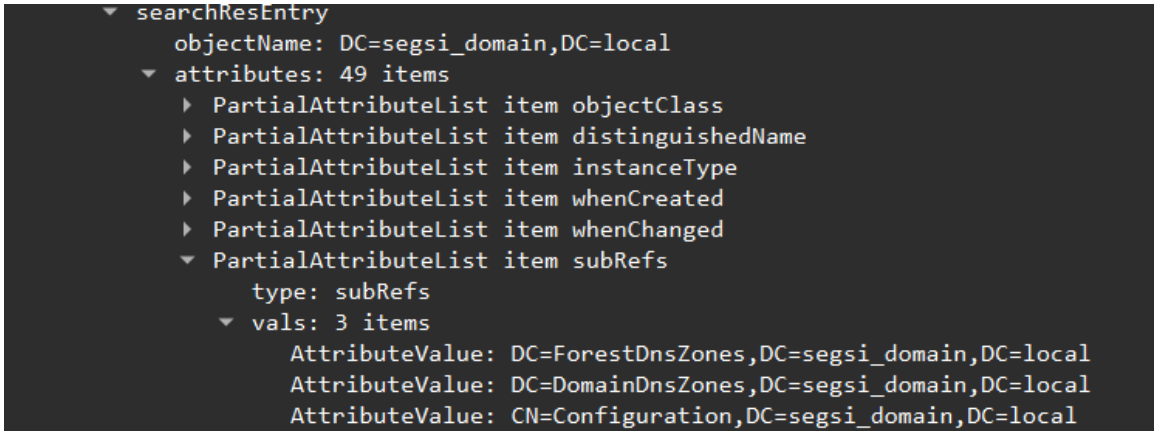


Figure 6 - LDAP response exposing domain and directory structure information

3.1.5.5 User Enumeration

LDAP search results capture also reveal actual objects found inside the Users container. Specifically, the LDAP query results include the built-in Administrator and the Alice Wonderland accounts.

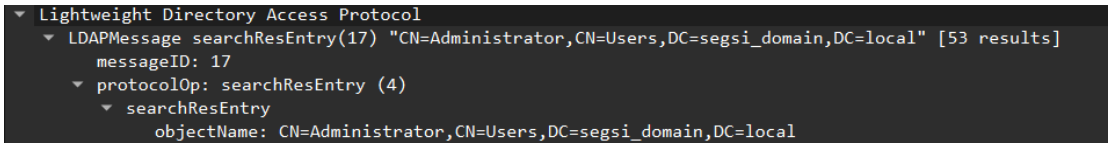


Figure 7 - LDAP Search Result exposing the Administrator account

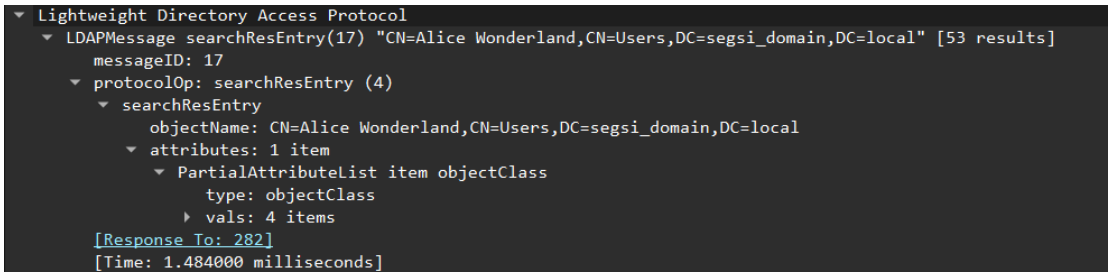


Figure 8 - LDAP Search Result exposing the Alice Wonderland user account

That one is able to identify such object names through the network traffic means that the contents of the directory can be enumerated from the unencrypted LDAP session.

3.1.6 Security Analysis

3.1.6.1 Vulnerability 1 - Plaintext credentials

However, the greatest problem from a security perspective in this capture is the exposure of the authentication secret in the LDAP Simple Bind Request. Both the distinguished name and password are readily available using Wireshark. This means that an attacker who can simply capture the traffic will be able to obtain valid LDAP credentials.

3.1.6.2 Vulnerability 2 - Unencrypted LDAP communication

The LDAP handshake occurs on TCP port 389, with no TLS. Since the data is not encrypted, the authentication credentials and directory query responses can be seen by the observer. Although the use of port 389 by itself does not necessarily pose a security risk if StartTLS is mandated, there is no TLS handshake in the current capture, indicating lack of encryption in this specific case.

3.1.6.3 Vulnerability 3 - Directory information disclosure

Search results reveal details about internal directory structures such as the domain distinguished name, schema and configuration paths, and DNS directory partitions. This data may assist an attacker to learn more about the directory structure and conduct further reconnaissance activities.

3.1.6.4 Vulnerability 4 - User enumeration

These search results show user objects like Administrator and Alice Wonderland under CN=Users. The revelation of legitimate usernames is useful in carrying out username guessing, password guessing, and other forms of attacks.

3.1.6.5 Vulnerability 5 - Infrastructure disclosure

The directory containers along with infrastructure-related naming details can also be found from the LDAP responses. Some of the examples seen in the capture are: CN=Configuration, CN=Builtin, CN=Computers, ForestDnsZones and DomainDnsZones. Such information helps in gaining more insight into the Active Directory environment.

3.1.7 Mitigation

Security problem	Evidence from capture	Suggested mitigation
Plaintext credentials	Simple Bind exposes the DN and authentication secret	Require TLS for LDAP authentication; disable Simple Bind over unprotected connections
Unencrypted LDAP traffic	LDAP data is readable over TCP/389	Use LDAPS on TCP/636 or require StartTLS on TCP/389; validate server certificates
Directory information disclosure	Schema, configuration and domain paths are observable	Apply least-privilege LDAP ACLs and restrict directory queries to authorized identities
User enumeration	Administrator and Alice Wonderland objects are returned	Limit unnecessary read permissions and prevent anonymous or excessive directory enumeration
Infrastructure disclosure	Domain containers and DNS partitions are visible	Segment directory services, firewall LDAP access to authorized systems,

		and monitor unusual LDAP search activity

3.1.8 Conclusion

Capture 1 is a case of successful LDAP authentication and search on the server located at 192.168.170.130 against the one with IP 192.168.170.132. The authentication process takes place through LDAP Simple Bind, after which the client runs several searches which return details about the domain structure and the directory objects.

In terms of security, the example captures the risks involved with sending LDAP traffic unencrypted. The authentication secret can be found in plaintext, while later responses show the scheme, configuration, and details of the domain/user. The successful Bind Response further validates the validity of the credentials used in this capture.

Encryption of LDAP traffic via LDAPS or StartTLS is mandatory, while Simple Bind should not be allowed on unprotected connection. The least privileges principle should be implemented on directory permissions, while the directory service should be minimized in exposure by the use of proper network segregation, access control and monitoring.

3.2 Capture nº.2

3.2.1 Overview

Capture 2 illustrates the creation of a session with POP3 where the client machine at 192.168.2.100 successfully created the connection to the server 64.246.26.20 over TCP port 110 that is used by unsecured POP3 sessions.

In this session, the client was able to authenticate, get mailbox information, retrieve one email message and delete it before closing the session.

This session raises some security considerations since there is no use of TLS when establishing the POP3 session. Therefore, the credentials used for authentication and the content of the email can be easily reconstructed.

Property	Observed value
Main protocol	POP3
Transport protocol	TCP
Client	192.168.2.100
Server	64.246.26.20
Server port	TCP/110
Username	test2@colasoft.com
Authentication result	Successful
Operations observed	STAT, UIDL, LIST, RETR 1, DELE 1, QUIT

3.2.2 Intervenients

The following is a list of the two hosts that take part in the communication process.

POP3 Client - 192.168.2.100

This host creates the TCP connection to the POP3 server and executes authentication and mailbox actions, which include STAT, UIDL, LIST, RETR, DELE and QUIT.

POP3 Server - 64.246.26.20

This host listens on TCP port 110 and answers POP3 request made by the client. The first message indicates that the service is mail.colasoft.com.

3.2.3 Main Protocol

The application layer protocol in this capture is called Post Office Protocol version 3 (POP3). POP3 is the protocol that enables email clients to retrieve emails from the mail server.

In this capture, POP3 works over TCP on port number 110. It involves textual client commands and server replies, usually starting with "+OK" in case the command has been accepted.

Since there is no TLS encryption in the session, credentials, commands, and messages can be easily seen by anyone monitoring the traffic.

3.2.4 Communication Analysis

Communication begins when 192.168.2.100 initiates a TCP connection to 64.246.26.20:110. Following the three-way TCP handshaking process, the POP3 server responds by sending out its greeting banner regarding the mail server.

Authentication is then performed using the USER and PASS commands. Successful authentication leads to querying for mailbox status using STAT, UIDL, and LIST; downloading message number one using RETR 1; deleting message one using DELE 1; and ending communication using QUIT.

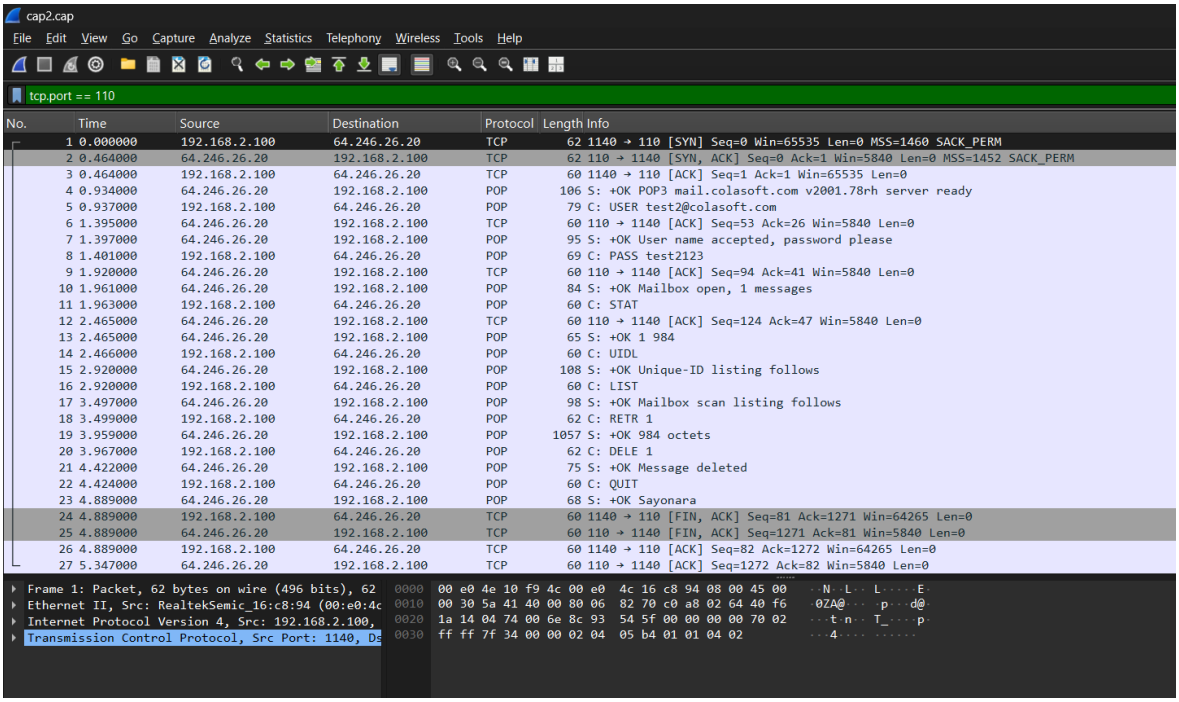


Figure 9 - Wireshark capture 2 showing POP3 communication between 192.168.2.100 and 64.246.26.20

3.2.5 Follow Stream Analysis

3.2.5.1 Authentication

The client starts the process of authentication with the command USER test2@colasoft.com. The server receives the name and asks for the password. This is provided in the message PASS test2123 which is also plainly visible in the POP3 stream.

The authentication was successful as evident from the mailbox response that follows. As the connection is not secure, the username and password can be extracted from the capture packets.

```
+OK POP3 mail.colasoft.com v2001.78rh server ready

USER test2@colasoft.com

+OK User name accepted, password please

PASS test2123
```

Figure 10 - POP3 authentication reconstructed using Wireshark Follow TCP Stream

3.2.5.2 Mailbox Information

Upon successful authentication, the client sends a request for the mailbox data. STAT provides the mailbox statistics, UIDL provides the unique identifier for the stored message, and LIST provides the mailbox scan listing.

The stream then displays the RETR 1 command, where the first message from the mailbox is retrieved.

```
+OK Mailbox open, 1 messages

STAT

+OK 1 984

UIDL

+OK Unique-ID listing follows
1 4224ff1c00000001
.

LIST

+OK Mailbox scan listing follows
1 984
.

RETR 1
```

Figure 11 - POP3 mailbox information and retrieval request

3.2.5.3 Email Retrieval

When RETR 1 is delivered, the server delivers the whole email in plaintext format. This stream shows the headers of the email message, which include the Return-Path, Received headers, sender, and recipient fields, and the subject.

The body of the message can be seen as well. In this case, the email has a subject of “test email!” and body of “Hello test2, this email is test!”.

```
+OK 984 octets
Return-Path: <test1@colasoft.com>
Received: from mail.colasoft.com (Unknown UID 8@localhost)
          by colasoft.com (8.11.6/8.11.6) with ESMTP id j21NjO300738
          for <test2@colasoft.com>; Tue, 1 Mar 2005 17:45:24 -0600
X-Authentication-Warning: mail.colasoft.com: Unknown UID 8 owned process doing -bs
X-ClientAddr: 222.210.195.15
Received: from colasoft_test_1 ([222.210.195.15])
          (authenticated (0 bits))
          by mail.colasoft.com (8.11.6/8.11.6) with ESMTP id j21NjMd00731
          for <test2@colasoft.com>; Tue, 1 Mar 2005 17:45:23 -0600
Message-Id: <200503012345.j21NjMd00731@mail.colasoft.com>
Date: Wed, 2 Mar 2005 10:19:39 -0800
From: "test1@colasoft.com" <test1@colasoft.com>
To: "test2" <test2@colasoft.com>
Subject: test email!
X-mailer: Foxmail 5.0 [en]
Mime-Version: 1.0
Content-Type: text/plain;
          charset="iso-8859-1"
Content-Transfer-Encoding: 7bit
Status:

Hello test2,

       this email is test!

Best regards,

test1
test1@colasoft.com
2005-03-02
.
```

Figure 12 - Email contents retrieved in plaintext through POP3

3.2.5.4 Message Deletion

After the message is retrieved, the client sends DELE 1, and the server confirms the deletion with +OK Message deleted. The session then ends with QUIT and the server replies +OK Sayonara.

3.2.6 Security Analysis

3.2.6.1 Vulnerability 1 - Plaintext credentials

The major issue with respect to the security of this capture is that the authentication credentials are sent in plain text. The POP3 stream shows the use of both the USER and PASS command, making known the username test2@colasoft.com and password test2123.

A hacker in such a position would be able to acquire the mailbox credentials without any direct intrusion into any endpoint.

3.2.6.2 Vulnerability 2 - Weak Password

Other than being transmitted in the absence of any encryption, the noted test password 'test2123' has an easy-to-guess format. A weak password such as the one described above has little defense against password guessing attacks.

Better password policies need to be put into place.

3.2.6.3 Vulnerability 3 - Email confidentiality

The session reveals all the details contained in the message. The RETR 1 command gives details about the email's metadata and message, including its sender, recipient, and subject/body text.

This is an absolute violation of confidentiality, since it is possible to deduce private messages from the intercepted network communications.

3.2.6.4 Vulnerability 4 - Mailbox activity disclosure

Mailbox functions like STAT, UIDL, LIST, RETR, and DELE can be seen from the trace. If an attacker sees this connection, he can tell how the user is using the mailbox, and what messages he is getting or deleting.

3.2.6.5 Vulnerability 5 - Service fingerprinting

The first POP3 banner reveals information about the service, revealing that the hostname is mail.colasoft.com. This information can be used by an attacker for reconnaissance and profiling of the service.

3.2.7 Mitigation

Security problem	Evidence from capture	Mitigation
Plaintext credentials	USER and PASS observable	Replace unencrypted POP3 with POP3S over TLS and disable insecure plaintext access where possible.
Weak authentication secret	Simple password test2123 observed	Enforce stronger password policies and consider MFA where supported.
Email content exposure	RETR 1 reveals complete message contents	Encrypt the communication channel to protect message confidentiality.

Mailbox activity disclosure	STAT, UIDL, LIST, RETR and DELE visible	Use TLS and restrict access to the mail service to authorized clients and networks.
Service information disclosure	POP3 banner reveals server information	Reduce unnecessary banner disclosure where operationally appropriate.
Unrestricted observation of POP3 traffic	Complete session reconstructable	Apply network segmentation and access controls around mail services.

3.2.8 Conclusion

Capture 2 is a good example of a secure POP3 connection from the client 192.168.2.100 to the mail server 64.246.26.20 where the client is authenticated with the test2@colasoft.com, gets mailbox information, receives an email and deletes it.

Confidentiality is the most critical vulnerability shown here. Credentials which have been used for the authentication process and the email received were completely unprotected.

This capture is the best evidence that plain POP3 shouldn't be used on untrusted networks. Instead of this, POP3S/TLS and other security controls should be applied.

3.3 Capture nº.3

3.3.1 Overview

Capture 3 shows an FTP session established between two systems in the local network. The FTP client in 192.168.2.101 creates a TCP connection to the FTP server in 192.168.2.100 running on port 21.

The client performs directory listing tasks and retrieves two executable files through the FTP session.

The current FTP session is a major security risk because the FTP control channel does not provide any protection against passive attacks. It is possible to derive the user ID and password from the network data.

Property	Observed value
Main protocol	FTP
Transport protocol	TCP
Client	192.168.2.101
Server	192.168.2.100
FTP control port	TCP/21
FTP data mode	Active
Username	administrator
Authentication result	Successful
Files retrieved	logagent.exe, mplayer2.exe

3.3.2 Intervenients

There are two primary hosts that engage in the communication process.

FTP Client – 192.168.2.101

This host establishes the TCP connection to the FTP server and then carries out the authentication, listing, and retrieval processes.

FTP Server – 192.168.2.100

This host accepts the connection on TCP port 21. The FTP banner for the service running on the host is colasoft_test_2 Microsoft FTP Service (Version 5.0).

The user taking part in the FTP authentication process is administrator.

3.3.3 Main Protocol

The application layer protocol that was seen in the capture is the File Transfer Protocol (FTP). FTP works on the Transmission Control Protocol (TCP).

In this case, the FTP control connection was made on TCP port 21, where the command and response exchange takes place. Meanwhile, other data connections are made for directory and file transfer.

Since PORT commands were used, the FTP session in this case runs on FTP active mode. This is because the client gives the server the information on which data connection to make.

3.3.4 Communication Analysis

Communication starts when 192.168.2.101 sends out the TCP connection request to 192.168.2.100:21. The TCP three-way handshake (SYN -> SYN/ACK -> ACK) process creates the connection prior to the FTP communication.

Upon creating the connection, the server identifies itself with the FTP 220 reply message:

220 colasoft_test_2 Microsoft FTP Service (Version 5.0).

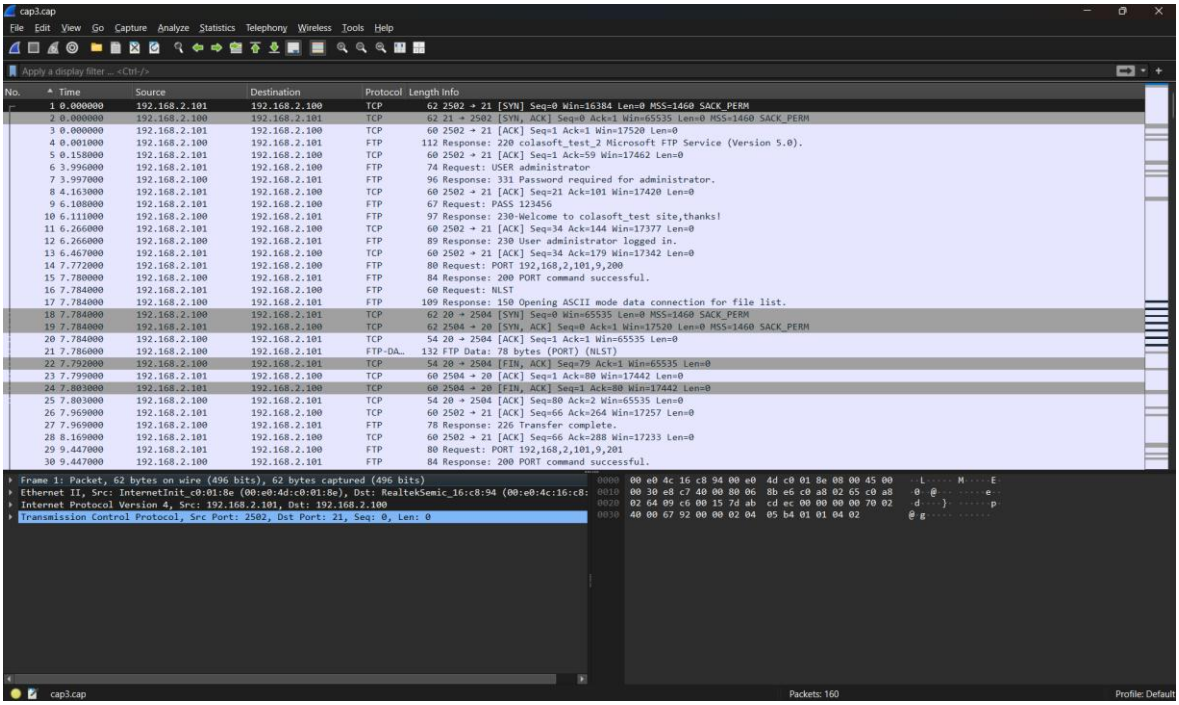


Figure 13 - Wireshark capture 3

3.3.5 Follow Stream Analysis

3.3.5.1 Authentication

Client starts authentication with:

USER administrator

Server gives the status code of 331 and asks for the password. Password is then provided by the client over the FTP control connection.

Server gives the status code of 230 and provides the message of “User administrator logged in”, showing that the authentication process was successful.

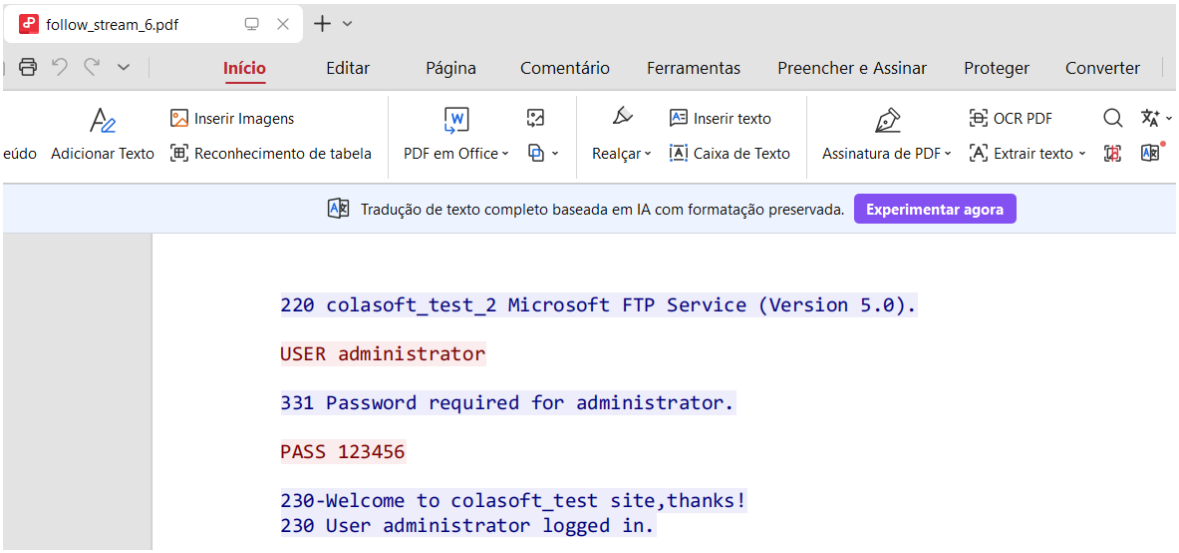


Figure 14 -FTP authentication reconstructed using Wireshark Follow TCP Stream

3.3.5.2 Directory Listing

Following authentication, the client asks for details regarding the files present on the FTP server.

NLST is used to ask for file names, whereas LIST is used to ask for more detailed file directory listing.

Prior to each data transfer, the client sends a PORT command. This reflects the use of active mode FTP.

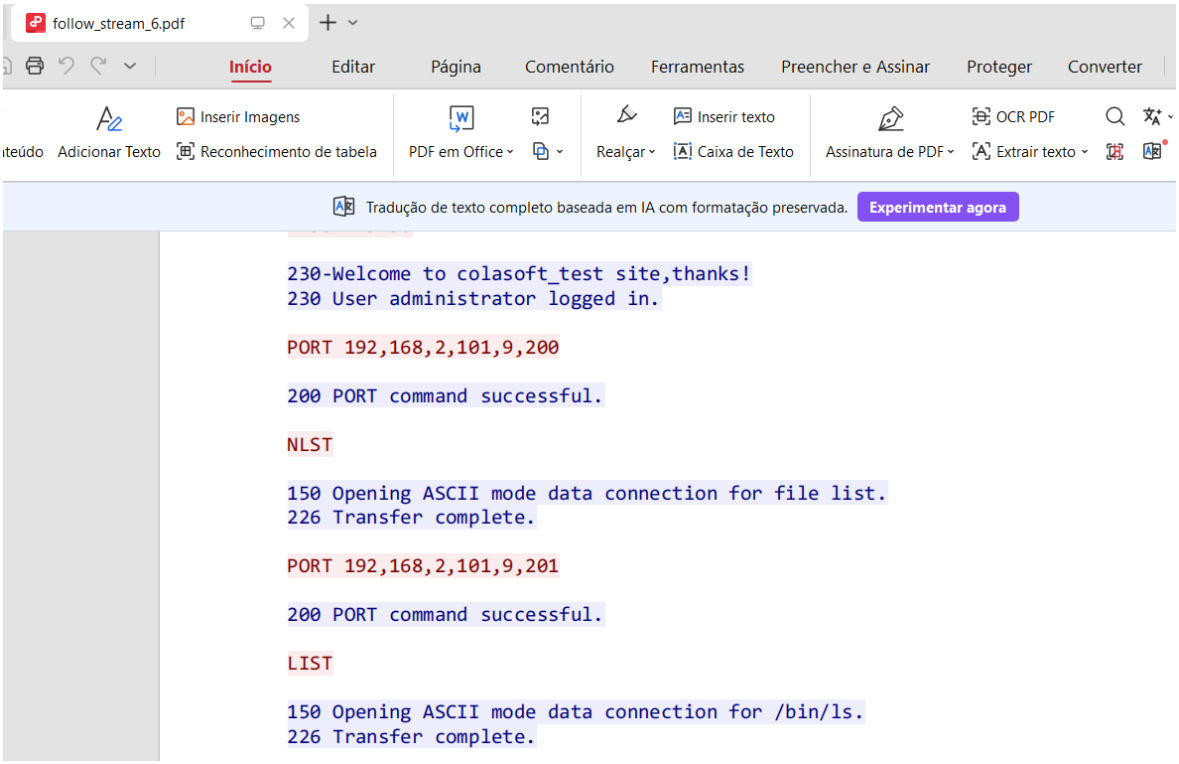


Figure 15- FTP directory listing

3.3.5.3 Transfer of logagent.exe

The client then sends the command RETR logagent.exe, asking the server to transfer the file.

The server gives information about the size of the file, which is 65,296 bytes, and creates a data connection for the file. The process ends by returning FTP response 226.

```
200 PORT command successful.

RETR logagent.exe

150 Opening ASCII mode data connection for logagent.exe(65296 bytes).
226 Transfer complete.
```

Figure 16 - FTP transfer logagent.exe

3.3.5.4 Transfer of mplayer2.exe

In a second request for file retrieval, the file requested is mplayer2.exe. The size of the file is 4,639 bytes, and the retrieval process ends with a 226 Transfer complete message.

While both transferred files end with the .exe extension, the mere packet capture alone does not provide any indication that they are harmful.

```
RETR mplayer2.exe

150 Opening ASCII mode data connection for mplayer2.exe(4639 bytes).
226 Transfer complete.
```

Figure 17 - FTP transfer mplayer2.exe

3.3.5.5 XPWD

XPWD command is sent by the client too. This command is met with 257 "/" is current directory from the server side as a reply.

```
XPWD

257 "/" is current directory.

PORT 192,168,2,101,9,204

200 PORT command successful.
```

Figure 18 - XPWD

3.3.6 Security Analysis

3.3.6.1 Vulnerability 1 - Plaintext credentials

The primary problem of security which arises from this capture is the sending of authentication credentials on the FTP control connection in plaintext.

Wireshark's TCP stream shows that both the commands USER and PASS have been sent, and the following message 230 User Administrator logged in confirms that this was indeed an authentication attempt.

Therefore, if an attacker were able to passively sniff this traffic, he would be able to acquire the credentials without having to attack either end-point.

3.3.6.2 Vulnerability 2 - Weak Password

In addition to its transmission without any confidentiality measures in place, the observed password from the capture is based on an extremely simplistic numerical pattern. This kind of credential offers little protection against attempts at password guessing.

Stronger passwords and more advanced forms of authentication must be implemented.

3.3.6.3 Vulnerability 3 - Privileged account

The username “administrator” indicates a possible sensitive user; but capturing this username alone does not indicate the privileges assigned to this FTP user. Regardless of the privileges, the disclosure of valid user credentials is still a threat to security.

3.3.6.4 Vulnerability 4 - File-transfer confidentiality

Transport insecurity not only reveals the identity of the communicating processes but also reveals the identity of the files accessed by these processes. Here in this capture, it can be seen that the client accesses logagent.exe and mplayer2.exe.

3.3.6.5 Vulnerability 5 - Service fingerprinting

The FTP banner is indicative of the server implementation. The information obtained could be helpful to reconnaissance, since it allows the attacker to understand what technology is being exposed.

3.3.7 Mitigation

Security problem	Evidence from capture	Mitigation
Plaintext credentials	USER and PASS observable	Replace plain FTP with an encrypted file-transfer mechanism such as SFTP or appropriately configured FTPS
Weak authentication secret	Simple numeric password observed	Enforce stronger password policies and consider MFA where supported
Account credential exposure	Successful authentication visible	Apply least privilege and restrict accounts permitted to access file-transfer services
File-transfer metadata exposure	RETR logagent.exe, RETR mplayer2.exe visible	Encrypt the communication channel
Service information disclosure	FTP banner identifies Microsoft FTP Service	Reduce unnecessary banner disclosure where operationally appropriate
Unrestricted observation of FTP traffic	Complete session reconstructable	Network segmentation and access controls around management/file-transfer services

3.3.8 Conclusion

Capture 3 reflects a successful FTP session between the IP address 192.168.2.101 and the FTP server with an IP address 192.168.2.100. After creating the TCP control connection, the client logs into the server as the administrator, does directory listing and downloads the logagent.exe and mplayer2.exe files.

The main security problem illustrated by the capture is the lack of confidentiality protection on the FTP control channel. Authentication credentials can be recovered from the network packets, and then the server confirms their legitimacy. Information about the server software and files accessed is also available.

Thus, the capture illustrates the reasons why FTP is not an appropriate protocol for transmitting confidential information and credentials over unsecured networks. Encrypted file transfer methods, proper authentication measures, credential policy improvements and network access restrictions should be applied to mitigate this problem.

3.4 Capture nº.4

3.4.1 Overview

Capture No. 4 consists of 242 packets and mainly comprises a Telnet session between two hosts on a private network. The analysis was done through Wireshark, mainly analyzing the connection established between both TCP and Telnet, and commands and other options that were used during the remote session.

The most important finding from this packet is the disclosure of login credentials and file contents due to an insecure Telnet session. Through TCP stream reconstruction, it was possible to find that there was an attempted login, followed by the successful authentication process, and reading information in a file in the remote computer.

3.4.2 Intervenients

There are two primary hosts involved in this communication:

Client: 192.168.251.1 with TCP source port 36099.

Server: 192.168.251.11 with TCP port 23.

It is the client that establishes a connection and communicates with the other host. The server refers to Microsoft Telnet Service and gives access to the command line interface of the Windows operating system once authenticated.

Both IPs are from the private address range. The packet capture also includes NBNS, ICMP and DHCP packets.

3.4.3 Main Protocol

Telnet is a higher level protocol used to provide interactive access to remote terminals using TCP connections. The default port number for Telnet is TCP 23.

During the connection process, negotiation for terminal options is performed between the client and server. These include echoing capabilities, terminal type, and terminal features.

The key disadvantage of Telnet from a security perspective is that it does not offer any mechanism for encryption of application layer information. Thus, authentication information, commands, and command responses may be intercepted.

3.4.4 Communication Analysis

Establishing TCP Connection

Firstly, there is TCP three-way handshake:

Packet 1: 192.168.251.1:36099 → 192.168.251.11:23 – SYN.

Packet 2: 192.168.251.11:23 → 192.168.251.1:36099 – SYN-ACK.

Packet 3: 192.168.251.1:36099 → 192.168.251.11:23 – ACK.

This handshake establishes TCP connection necessary for the Telnet session.

Negotiation of Telnet Options

After establishing connection, the server starts negotiating Telnet options.

Packet 4 contains negotiation parameters related to echo, terminal type, window size and terminal speed. Further negotiations are seen in packets 14, 16 and 18.

This negotiation sets the configuration for the interactive terminal session.

Authentication Process

The process of authentication has been reconstructed using Wireshark Follow TCP Stream feature.

At the beginning, server presents the message Welcome to Microsoft Telnet Service and asks for username.

The entered username is esegi-boss.

There are two attempts of authentication performed:

In the first attempt, the used password is segredo and the server denies the credentials and presents Logon failure: unknown user name or bad password, followed by Login Failed.

In the second attempt, the used password is segred0. After the second attempt, server shows the message about the Microsoft Telnet Server and provides access to the Windows command prompt.

The successful authentication is shown by the following prompt:

C:\Documents and Settings\esegi-boss>

This means that the second set of credentials was recognized on the remote side.

Remote Command Execution

After successful authentication, the user works with the Windows file system via the Telnet connection.

The commands found in the reconstructed dialogue include the following:

cd \ — Switches the current directory to the root of drive C.

dir — Shows the contents of the root directory.

cd secrets — Switches to the C:\secrets directory.

dir — Lists the files/subdirectories in the C:\secrets directory.

type pin.txt — Shows the contents of the pin.txt file.

exit — Closes the remote command-line session.

As can be seen from the first dir command, there are some directories, such as Documents and Settings, Inetpub, Program Files, WINDOWS and secrets.

Within C:\secrets, there is the more subdirectory and two files pin.txt and ushhh.doc.

The pin.txt file is said to be composed of five bytes. On executing the command type pin.txt, the server sends 89384.

Thus, it is evident that the content of the file was transmitted via Telnet and could be intercepted from the captured traffic.

More Network Traffic

Apart from the Telnet traffic, there is other information in the capture, such as NBNS name queries, Destination Unreachable messages and DHCP Requests/ACK.

For instance, packet 5 and packet 6 have an NBNS name query and ICMP Port Unreachable message respectively. Packet 12 and 13 have a DHCP Request and a DHCP ACK respectively.

This suggests that there were other network activities occurring during the capture. But this does not affect the conclusion regarding the confidentiality of the Telnet session.

3.4.5 Security Analysis

Plaintext Credential Disclosure

From this capture, it can be seen that the authentication credentials are not encrypted during transmission.

Both passwords, segredo and segred0, are available in the reconstructed TCP stream. In addition, the username esegi-boss is captured.

It is a very serious issue in terms of confidentiality since an attacker able to capture the traffic would obtain the authentication credentials.

Administrative Commands Exposure

The reconstructed session also shows the commands used during the session after authentication.

It can be seen the directories that were accessed, the files that were listed and the commands used to get the information.

It provides details about the remote host and user activity.

Disclosure of Sensitive Information

When running type pin.txt, the number 89384 is captured.

It is clear from this capture that the confidentiality problem is not related to login credentials only. It also concerns file contents.

Disclosure of Information Using Directory Enumeration

The dir commands illustrate the structure of the remote filesystem and also identify some of the files that may have confidential information.

Even though this capture cannot show whether all these files have confidential information, the directories show some information that can help the attacker to find some targets.

3.4.6 Mitigation

The main mitigation strategy is replacing Telnet with SSH to enable secure remote terminal access.

Other security controls that may be considered include limiting remote access to only authorized hosts, stopping unneeded services, requiring strong authentication, and securing sensitive data with proper access control.

It is also necessary to change any credentials that have been transmitted in plaintext, especially if they are still valid.

3.4.7 Conclusion

Capture No. 4 highlights the security issues arising from use of Telnet for remote system administration.

As seen from the reconstructed conversation, there were two cases of authentication, access to the Windows command shell, listing of directories, and extraction of PIN from a text file.

The capability to retrieve the authentication credentials and file contents is an indication that no confidentiality was provided by the Telnet connection.

This capture brings out the necessity of employing secure remote access protocols alongside other authentication and authorization procedures.

3.5 Capture nº. 5

3.5.1 Overview

In capture no.5, there is a short RADIUS authentication session involving two packets. This interaction takes place between the hosts 192.168.170.135 and 192.168.170.131 via UDP.

The first packet is a RADIUS Access-Request from 192.168.170.135 towards the RADIUS authentication service located at 192.168.170.131:1812. The second packet is an Access-Accept message from the server.

Property	Value
Number of packets	2
Main protocol	RADIUS
Transport protocol	UDP
RADIUS Client/NAS	192.168.170.135
RADIUS Server	192.168.170.131
Server port	1812/UDP
Authentication mechanism observed	MS-CHAP
User	bob
Result	Access-Accept

3.5.2 Intervenients

There are two participants to the captured communications:

RADIUS Client / NAS - 192.168.170.135

This participant starts the authentication exchange by sending packets with source UDP port 58157. The RADIUS Attributes reveal that Network Access Server is identified by NAS-IP-Address 192.168.170.135 and NAS-Identifier pfSense.home.arpa.

RADIUS Server – 192.168.170.131

This participant captures the authentication request on UDP port 1812 and replies with RADIUS Response packet.

Access-Request reveals the user who participates in the authentication procedure as bob.

3.5.3 Screenshot 1

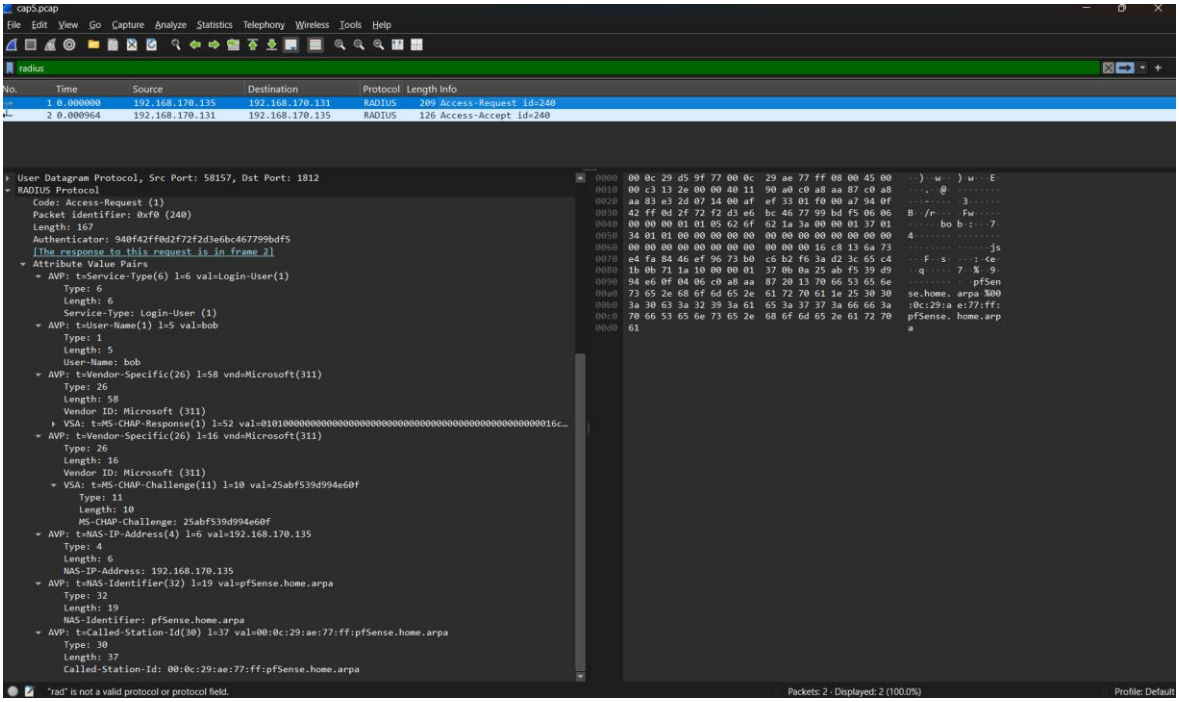


Figure 19 - RADIUS Access-Request sent by 192.168.170.135 to 192.168.170.131

Summary:

Packet 1: 192.168.170.135 → 192.168.170.131

RADIUS Protocol: Code: Access-Request (1)

Attribute Value Pairs:

Service-Type: Login-User

User-Name: bob

MS-CHAP-Response

MS-CHAP-Challenge

NAS-IP-Address: 192.168.170.135

NAS-Identifier: pfSense.home.arpa

3.5.4 Main Protocol

This capture consists mainly of the RADIUS protocol (Remote Authentication Dial-In User Service). In this exchange, the RADIUS protocol runs on UDP, where the RADIUS server gets the request at port 1812.

The RADIUS protocol is used to conduct an authentication and access control process. The access request contains user information and authentication method, and the server responds with Access-Accept.

3.5.5 Performed Operations

3.5.5.1 Access-Request

The communication is initiated by sending of the Access-Request from UDP port 58157 of the RADIUS client/NAS located at 192.168.170.135 to 192.168.170.131:1812.

The Access-Request carries the RADIUS Identifier 240 and consists of many attributes which describe the operation of authentication. The User-Name attribute states that the user is bob, and the Service-Type attribute takes the value Login-User.

Furthermore, there are MS-CHAP-Challenge and MS-CHAP-Response vendor-specific attributes from Microsoft which indicate that the MS-CHAP protocol is utilized for authentication. Information about the NAS includes its IP address 192.168.170.135 and NAS-Identifier pfSense.home.arpa, as well as the information about the Called-Station-Id 00:0c:29:ae:77:ff:pfSense.home.arpa.

3.5.5.2 Access-Accept

The RADIUS server operating at IP address 192.168.170.131 processes the request and sends back a response from UDP port 1812 to the original client port 58157.

The reply received by the client is an Access-Accept using the same RADIUS Identifier (240) as the original request. Wireshark explicitly links the reply to frame 1, showing a time difference of approximately 964 µs.

As the server sends out an Access-Accept message, it means that the authentication request for user bob has been accepted.

The reply includes several Microsoft specific attributes including MS-CHAP-MPPE-Keys encrypted, MS-MPPE-Encryption-Policy set to Encryption-Allowed and MS-MPPE-Encryption-Types set to RC4-40-128.

3.5.6 Screenshot 2

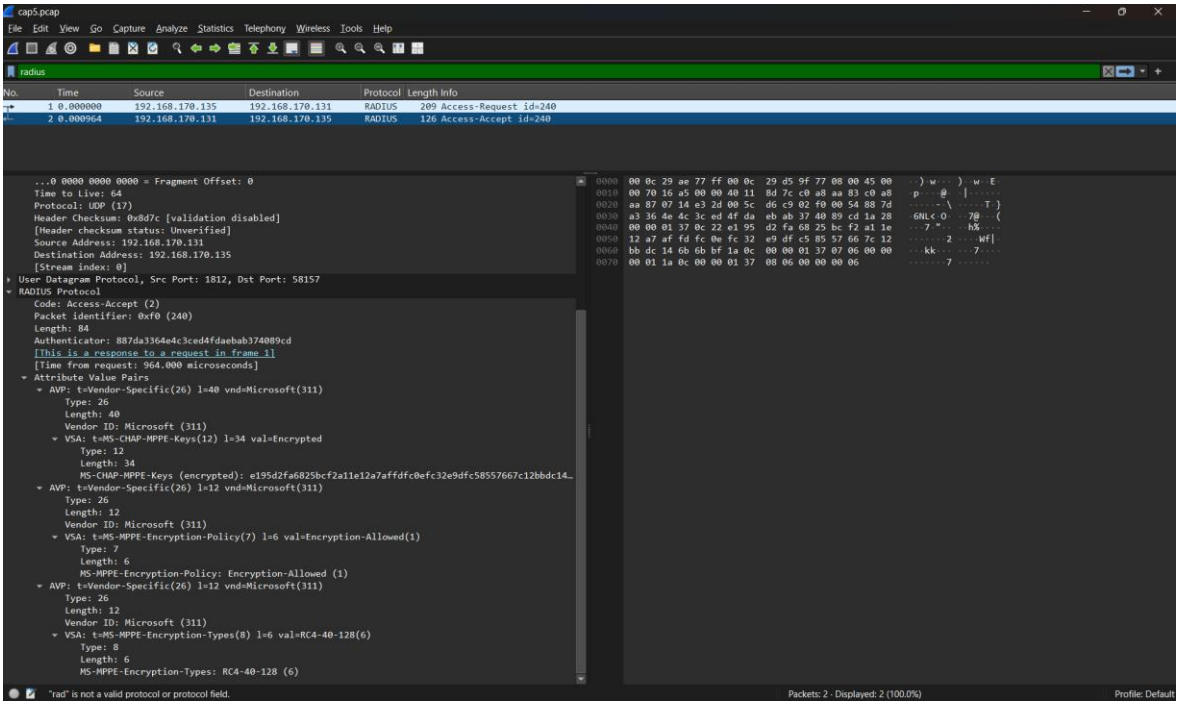


Figure 20 - RADIUS Access-Accept returned by 192.168.170.131

Summary:

RADIUS Protocol:

Code: Access-Accept (2)

Packet identifier: 0xf0 (240)

[This is a response to a request in frame 1]

[Time from request: 964.000 microseconds]

Attribute Value Pairs:

MS-CHAP-MPPE-Keys: encrypted

MS-MPPE-Encryption-Policy: Encryption-Allowed

MS-MPPE-Encryption-Types: RC4-40-128

3.5.7 Communication Analysis

3.5.7.1 Communication Sequence

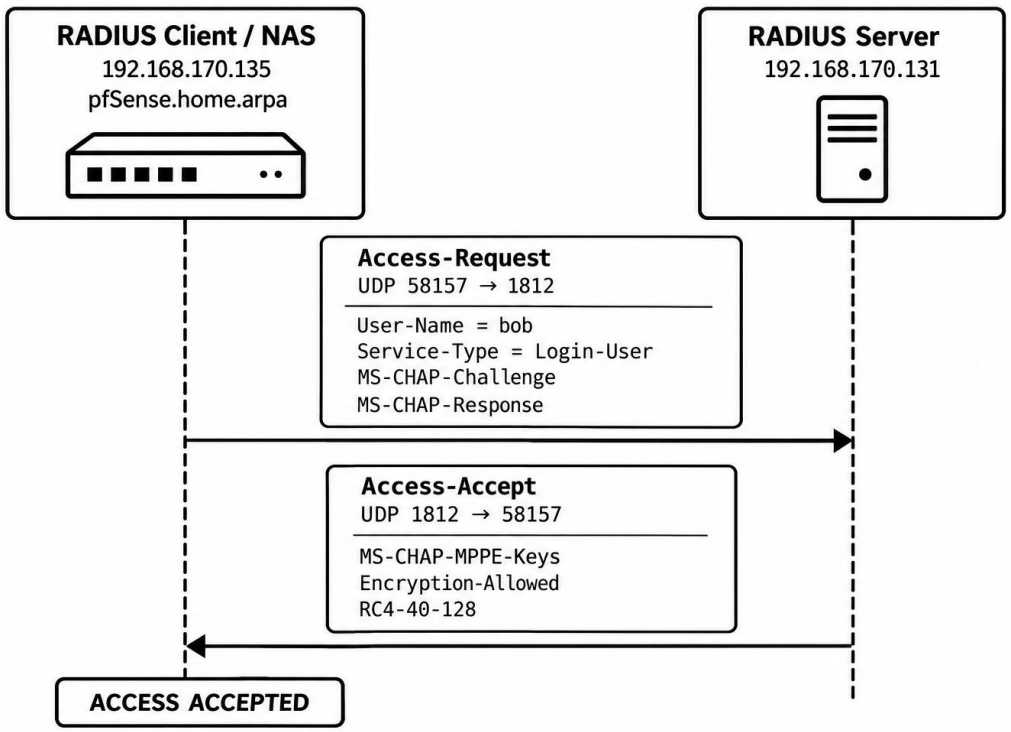


Figure 21 - Communication Sequence

3.5.7.2 Relationship with authentication, authorization and accounting (AAA)

This exchange can be linked with access control terms, such as identification, authentication, and authorization.

Identification can be seen with the help of the User-Name attribute, which tells us that the user is named bob.

Authentication can be seen in the MS-CHAP information provided in the Access-Request.

Access decision can be seen with the help of the Access-Accept response given by the RADIUS server, and it shows that the request has been accepted.

RADIUS may also be used for accounting purposes, but there is no accounting exchange in this capture.

3.5.8 Security Analysis

3.5.8.1 Vulnerability 1 - Information Disclosure

3.5.8.1.1 Evidence

In the Wireshark we obtain:

User-Name: bob

NAS-IP-Address: 192.168.170.135

NAS-Identifier: pfSense.home.arpa

Called-Station-Id: 00:0c:29:ae:77:ff:pfSense.home.arpa

3.5.8.1.2 Information Disclosure

Some of the metadata revealed from the intercepted RADIUS packets includes the username bob, the use of internal IP address scheme, the Network Access Server identifier pfSense.home.arpa and some data in the Called Station Id.

This information does not prove any disclosure of the plain-text password. But it reveals some information which may help an attacker in reconnaissance.

3.5.8.2 Vulnerability 2 - MS-CHAP exposure

3.5.8.2.1 Evidence

In the Wireshark we obtain:

MS-CHAP-Challenge

MS-CHAP-Response

3.5.8.2.2 MS-CHAP authentication information

Access Request makes the MS-CHAP challenge and response known to someone who intercepts the network traffic. The password is not available in plaintext in the capture. However, from this capture, it can be observed that the system uses MS-CHAP as an authentication mechanism and thus the security of the authentication method is open to scrutiny.

It is recommended to use a more secure authentication method and protect the authentication transport.

3.5.8.3 Vulnerability 3 - Legacy cryptographic mechanism

3.5.8.3.1 Evidence

In the Wireshark we obtain:

MS-MPPE-Encryption-Types: RC4-40-128

3.5.8.3.2 Legacy cryptographic configuration

The Access-Accept packet contains the attribute MS-MPPE-Encryption-Types, which has a value of RC4-40-128. This shows that the configuration included in the exchange supports RC4 MPPE encryption methods.

Legacy cryptography techniques need to be phased out wherever possible and replaced by current methods.

3.5.9 Mitigation

Security consideration	Evidence	Suggested mitigation
Exposure of authentication metadata	Username, NAS IP/identifier and station information are observable	Restrict access to the authentication network and protect the communication path
Exposure of MS-CHAP exchange information	Challenge and response observable	Prefer stronger authentication mechanisms where supported
Legacy cryptographic configuration	RC4-40-128 appears in MPPE encryption types	Replace legacy cryptographic mechanisms with currently supported alternatives
Exposure of AAA infrastructure	RADIUS client/server addresses and NAS information observable	Segment the AAA infrastructure and restrict communication to authorized RADIUS clients

3.5.10 Conclusion

Capture 5 shows a successful RADIUS authentication process from pfSense NAS located on 192.168.170.135 to the RADIUS server at 192.168.170.131.

The client initiates an Access-Request to authenticate the user bob through MS-CHAP related authentication attributes. The RADIUS server receives this request and returns an Access-Accept packet to show that the request was successfully authenticated.

In terms of security, we see metadata of both the authentication process and the underlying infrastructure. This includes the username, information about the NAS and MS-CHAP challenge/response pair. Moreover, the server claims that it is using RC4 based MPPE encryption algorithm. These observations show why AAA traffic should be protected against unauthorized access and usage of old authentication and cryptography techniques where better options exist.

3.6 Capture nº.6

3.6.1 Overview

In Capture No. 6, there is a single packet whose length is 418 bytes. This packet has been analyzed using Wireshark to understand its network and transport properties, the application layer protocol, as well as the security aspects, if any.

The packet is sent from the publicly accessible IP address of 218.232.95.60 to a privately assigned IP address of 192.168.1.4 via the UDP destination port 1434.

According to Wireshark, the application layer protocol used is the Distributed Computing Environment/Remote Procedure Call (DCE/RPC). The message used in this packet is a Ping message.

This is especially important since the UDP destination port number 1434 is used by Microsoft SQL Server Resolution service, which has been subjected to several attacks on SQL server infrastructure.

However, since we have just one packet, it is impossible to know the result of the communication or whether there was an attack or not.

3.6.2 Intervenients

The packet consists of two hosts:

Source: 218.232.95.60 with the source port of 3664 UDP.

Destination: 192.168.1.4 with the destination port of 1434 UDP.

The source IP address is the public IPv4 address, whereas the destination IP address is the private IPv4 address range.

The destination port is frequently used by Microsoft SQL Server Resolution Service. However, the usage of the port does not guarantee the existence of such a service on the destination machine.

3.6.3 Main Protocol

DCE/RPC (Distributed Computing Environment / Remote Procedure Call) is an inter-process communication protocol by which components of software can make requests for services from remote systems.

There are various transport protocols supported by DCE/RPC, such as UDP, and specific protocol fields used to indicate the operation, handle the communication process and perform authentication.

The protocol field of this captured packet indicates it is a DCE/RPC 4 Ping.

3.6.4 Communication Analysis

Network and Transport Features

Capture consists of packet number 1 only. Packet features are listed below:

Source IP address: 218.232.95.60.

Destination IP address: 192.168.1.4.

Transport layer protocol: UDP.

Source port: 3664.

Destination port: 1434.

Frame length: 418 bytes.

As UDP is a connectionless protocol, there is no TCP three-way handshake process.

There is no response packet from the destination host in the capture.

Analysis of DCE/RPC Header Fields

Details of DCE/RPC protocol show the following header fields:

Version: 4.

Packet type: Ping (1).

Flags1: 0x01.

Flags2: 0x01.

Sequence number: 16843009.

Operation number: 257.

Fragment length: 257.

Fragment number: 257.

Interface hint: 0x0101.

Activity hint: 0x0101.

Several byte sequences repeat in the packet.

For instance, sequence number 16843009 is equal to 0x01010101.

Such repetitions are uncommon, which suggests that either the packet was designed artificially or it is an incorrect application of some protocol data. However, this feature in itself does not provide any indication of a specific attack.

Data Representation

The Wireshark program represents the data representation as 0x010101, which means the following decoded parameters:

Byte Order – big-endian;

Character Encoding – EBCDIC;

Floating Point – VAX.

Such parameters are quite unusual considering the context of the modern networks using Windows operating system for data exchange.

Nevertheless, the data must be properly decoded as DCE/RPC to be interpreted. In turn, such unusual fields may be misleading and must not be interpreted as any malicious procedure.

Authentication Fields

The packet contains an authentication-related field that is recognized by Wireshark as Kerberos authentication verifier. The following fields are present:

Authentication Protocol - Kerberos Version 5 (1);

Protection Level - Unknown (226);

Key Version Number – 8.

It should be noted that the presence of the Kerberos authentication verifier does not indicate any successful authentication procedure.

Moreover, the unknown protection level makes this field even less informative.

Communication Outcome

There are no more packets that can be found.

For that reason, the capture does not tell us whether the destination received, rejected, or replied to the packet.

Furthermore, there is no indication of session establishment, exploitation, or any network activity after that.

3.6.5 Security Analysis

Traffic Directed to UDP Port 1434

The traffic is directed to UDP port 1434, which is connected with Microsoft SQL Server Resolution Service.

The port is known to be historical in relation to the vulnerabilities of SQL Server related services exploited via worms and other attacks.

Hence, the unsolicited traffic directed to the port must be checked in case the service is unnecessarily open for traffic.

Unusual Fields of Protocols

The packet contains the repeated byte patterns and unusual protocol fields, such as sequence number 0x01010101 and protection level unknown to Wireshark.

Those features may be indicative of the malformed traffic.

Nevertheless, they are not the factors that prove the nature of traffic being malicious.

Service Vulnerability Potential

In case the destination host uses a vulnerable service on UDP port 1434, the unsolicited traffic directed to that port is a potential problem.

Still, there is no proof of the vulnerability and its usage in the capture.

Limited Amount of Information

One of the key limitations is that there is one packet only in the capture.

Without the additional information, the purpose of the packet cannot be established.

3.6.6 Mitigation

The suggested actions comprise limiting access to UDP port 1434, turning off unnecessary services for database discovery, installation of updates for security and isolation of services within network segments.

Firewall should be configured to allow connections only from trusted hosts, where such a service is necessary.

Another tool for detecting possible threats could be intrusion detection and logging on network level.

3.6.7 Conclusion

Capture No. 6 features one UDP packet decoded by Wireshark as DCE/RPC Ping to port 1434.

The packet has unusual values for fields and repeated bytes, and therefore it is of interest from security perspective.

Nevertheless, there is no proof that an attack was made or that some exploit was used.

The current capture shows how to interpret evidence carefully and correlate suspicious activity with other network data.

4 PL02.ex1 - Active Directory and Kerberos

Environment	Windows Server 2019 on Oracle VirtualBox
Tools	BadBlood; SharpHound BloodHound Community Edition; Neo4j
Date	October 2026

4.1 Introduction and background

This exercise creates an Active Directory system and analyzes how interactions between users, groups, computers, and permissions may become attack paths. This is done by moving from deploying a directory service through creation of test objects to collecting and analyzing the generated privilege graph.

4.1.1 Active Directory and access control

Active Directory Domain Services (AD DS) organizes users and resources within a domain. The directory server maintains the directory and facilitates authentication and policy enforcement. Rights are assigned by groups to multiple users, and permissions are set by ACLs for the objects. Legitimate membership becomes an attack path in case of identity theft [1, 5, 6].

4.1.2 Kerberos in the domain

Key Distribution Center (KDC) is used by Kerberos; KDC is running on domain controller in Windows. After initial authentication, the client receives ticket-granting ticket (TGT). With this ticket, the client can ask for tickets for certain services without showing its password to each service separately [1].

Tickets distribution allows authentication, groups and permissions control access rights. Privilege graph allows evaluating how far can the account go but doesn't allow to conclude whether tickets of Kerberos were used to exploit or were forged.

4.1.3 Analysis method

The analysis proceeds according to the task requirements and relates findings to relevant figures. Visible directly findings are separated from assumptions about exploitation and validation actions suggested. The screenshots are numbered as C01-C44: C01 is a screenshot without the number, C02-C44 - with 1-43 suffix respectively. The cropped screenshots contain relevant information for the window and are referenced in the caption.

Additional screenshots include preparation of Windows 11 VM CLIENTE01. Linux configuration CLIENT01 is presented in Networking and BloodHound stages. They are considered as two different records without supposition about the same OS and about the client joining the domain.

4.2 Laboratory environment

The DC01 host has Windows Server 2019 Standard Evaluation operating system installed in VirtualBox. Figure 1 shows the edition, 8 GB RAM, and 59.46 GB of total hard disk space. The hostname of DC01 is proved by running the hostname command.

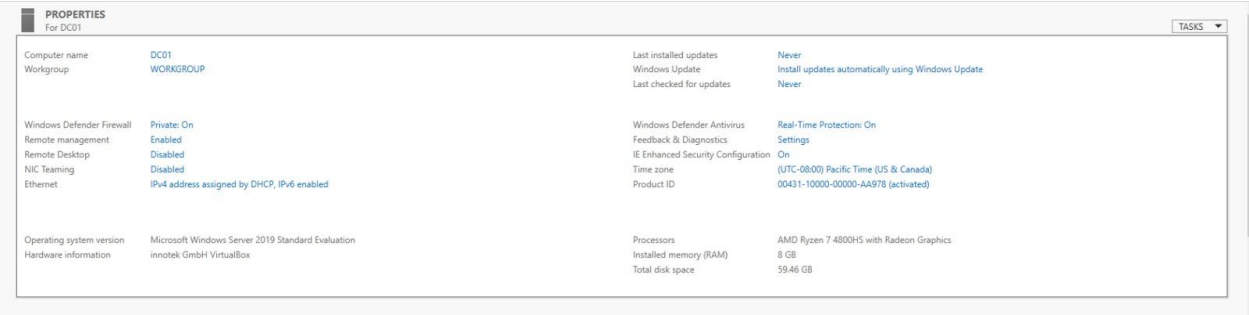


Figure 22 — DC01 server properties and virtual machine resources.

Component	Observed configuration
Domain controller	DC01.lab.local; Windows Server 2019 Standard Evaluation
Domain and forest	lab.local; NetBIOS name LAB
Internal network	LAB; address range 192.168.10.0/24
DC01 internal interface	192.168.10.10; preferred DNS 192.168.10.10
DC01 NAT interface	10.0.2.15; gateway 10.0.2.2
Linux workstation CLIENT01	Configured IPv4 192.168.10.20/24; DNS 192.168.10.10
Analysis tools	BadBlood; SharpHound 2.17.0.0; BloodHound CE 9.8.0
Data persistence	Neo4j container and Neo4j Desktop 1.6.3 records

The server adapters have a connection via the NAT connection and a connection to the internal LAB network. This setting covers the external connections and communications within the laboratory network, but it does not necessarily imply isolation.

4.2.1 System updates

All updates need to be installed in this test. In the state of the figure below, the last installed updates and last checked for updates are never. The OS installation is illustrated but all patches are not verified. This step cannot be achieved without the Windows Update history and updates inventory with pending updates check.

4.3 Server network configuration

Ethernet 2 interface employs the static address 192.168.10.10 and the subnet mask 255.255.255.0. The primary DNS server references the server itself. The lack of a gateway for this particular interface makes sense in light of the existence of another interface for external communication.

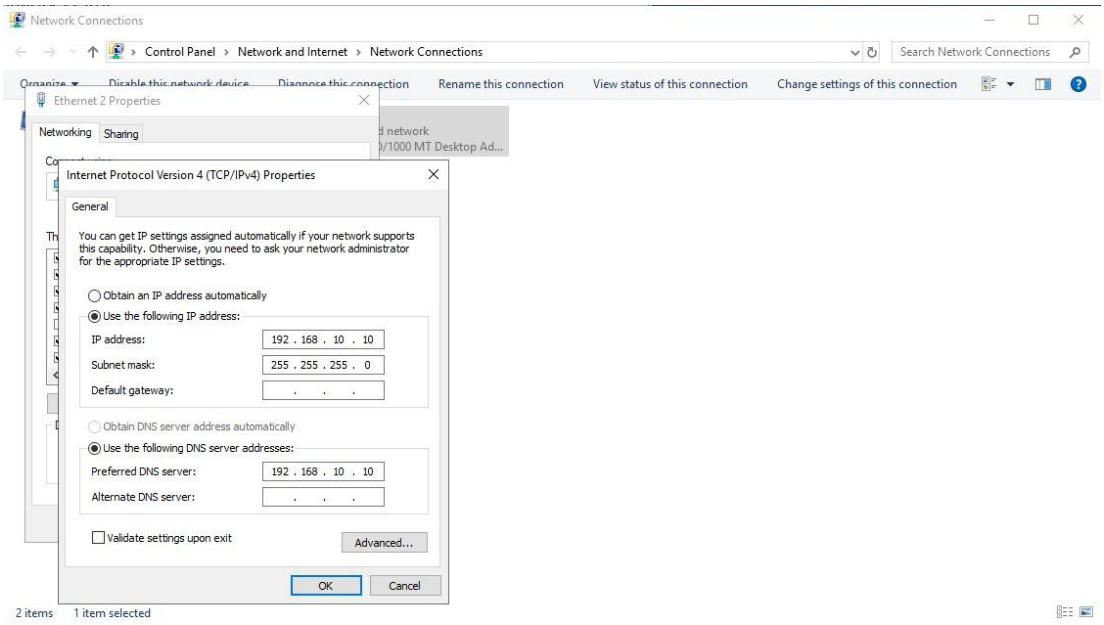


Figure 23 — Static addressing and DNS on the DC01 internal interface.

The output of ipconfig /all confirms both interfaces: Ethernet using DHCP on the NAT network and Ethernet 2 configured manually on the laboratory network.

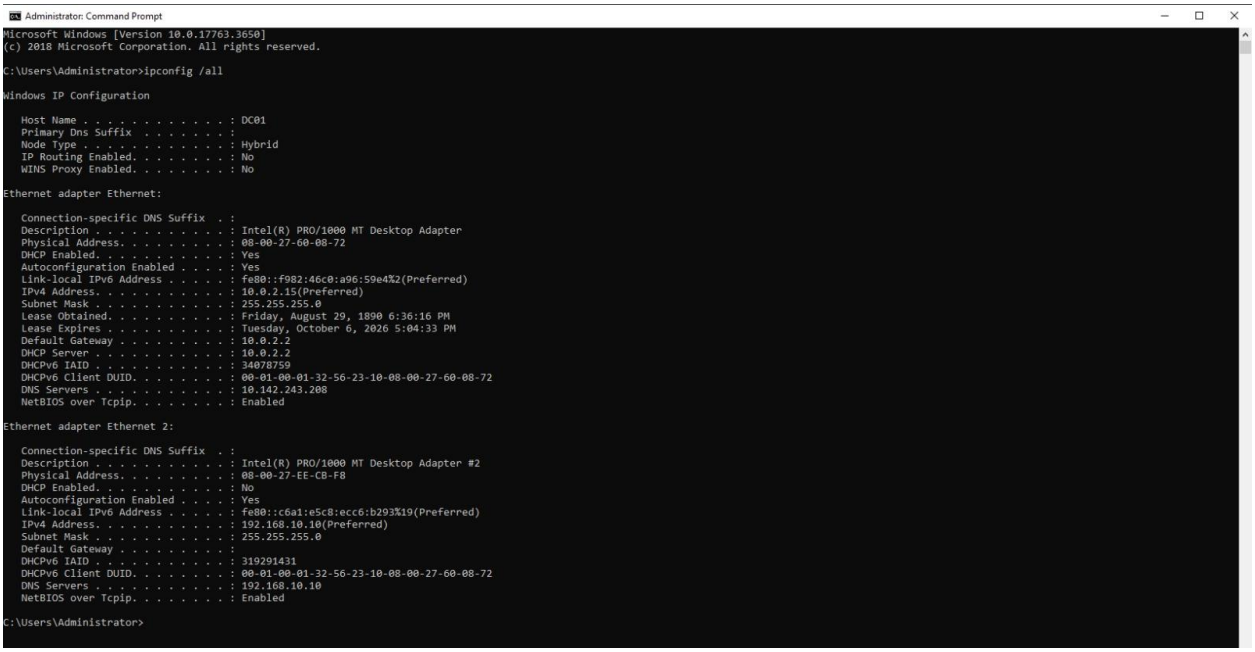


Figure 24 — NAT and internal interface settings shown by ipconfig.

4.4 Communication with the Linux workstation

Configurations for the Linux workstation through the graphical user interface include 192.168.10.20/24 and the DNS server 192.168.10.10. The following tests are meant to verify IP communication and domain name resolution of DC01.

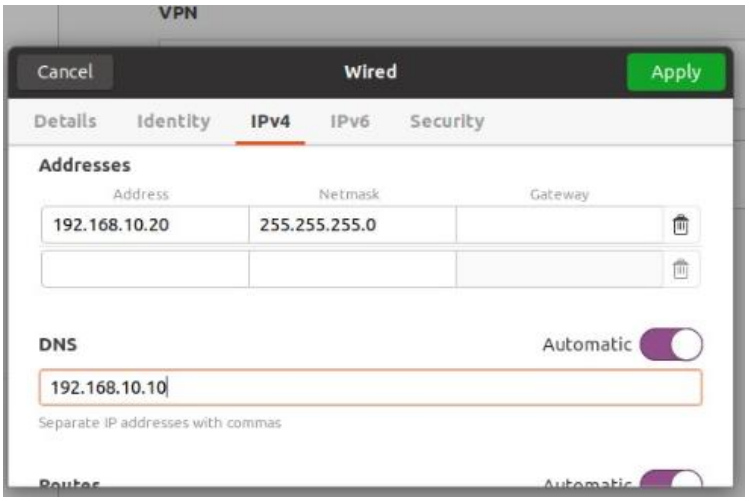


Figure 25 - IPv4 configuration and DNS server on the Linux workstation.

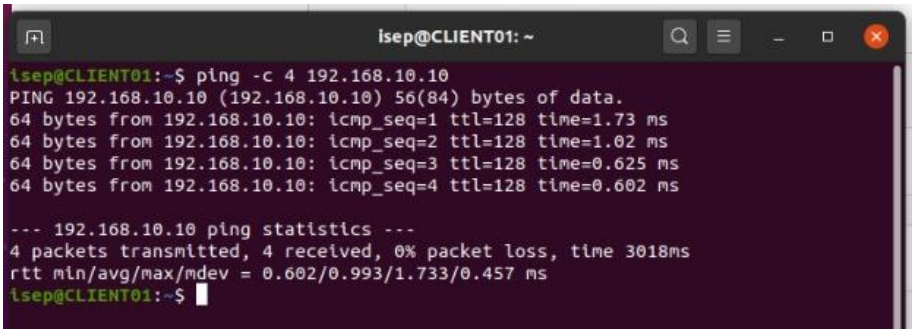


Figure 26 - Four replies from DC01 with zero per cent packet loss.

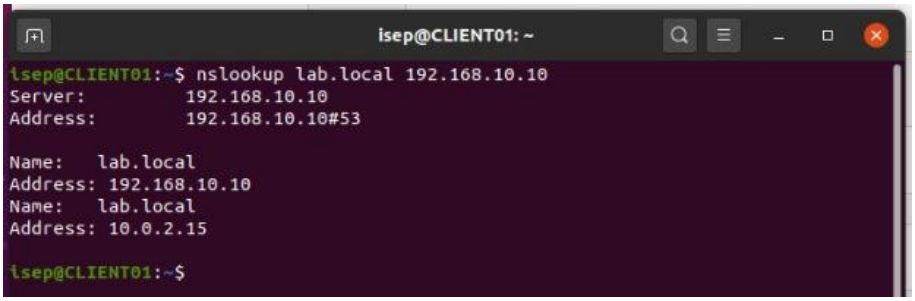


Figure 27 - Resolution of lab.local through the DC01 DNS server.

The command nslookup lab.local 192.168.10.10 gives two IP addresses 192.168.10.10 and 10.0.2.15. The latter is the NAT interface IP of the server and must be checked in DNS. Name resolution must result in an IP that can be reached by clients in the internal network. The ping test indicates that IP reachability works, but not domain validation.

4.5 Directory service installation

The Add Roles and Features Wizard was used to select the Active Directory Domain Services role for DC01. Role installation gets the server ready, but creation of the domain involves the next promotion phase.

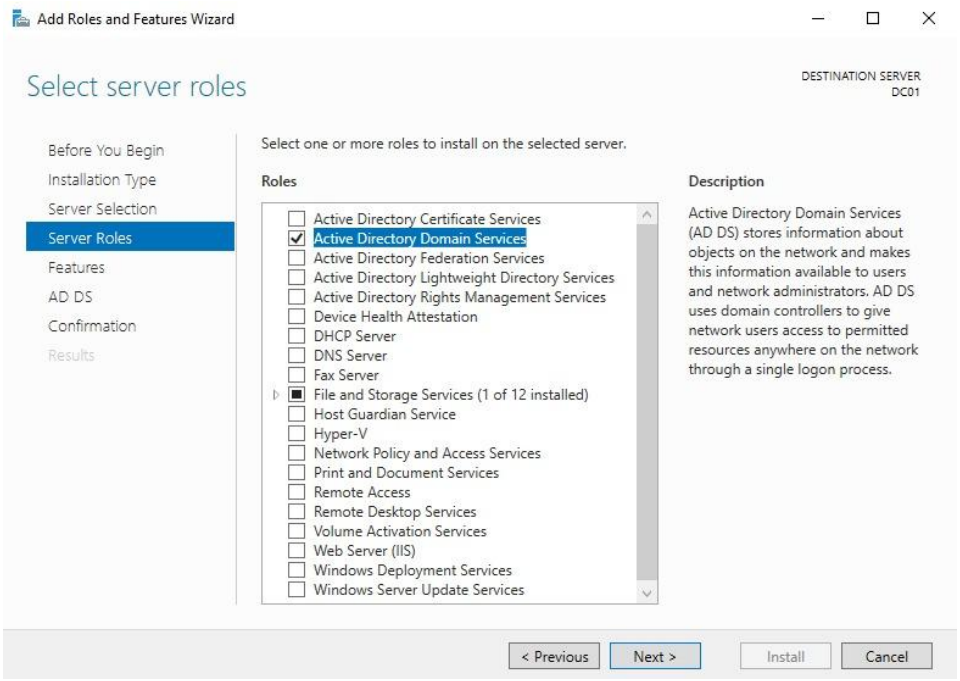


Figure 28 - Selection of the Active Directory Domain Services role.

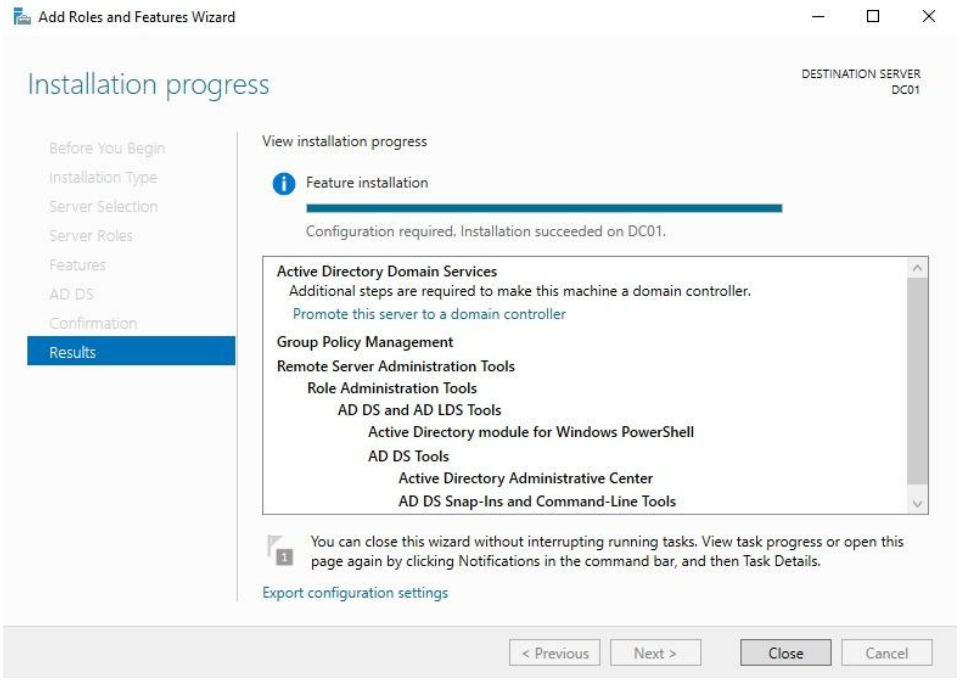


Figure 29 - AD DS installation completed with additional configuration required.

4.6 Forest and domain creation

Promotion Wizard is used to select “Add a new forest” option and set “lab.local” as the root domain. The below options enable setting up Windows Server 2016 functional levels and DNS and Global Catalog services.

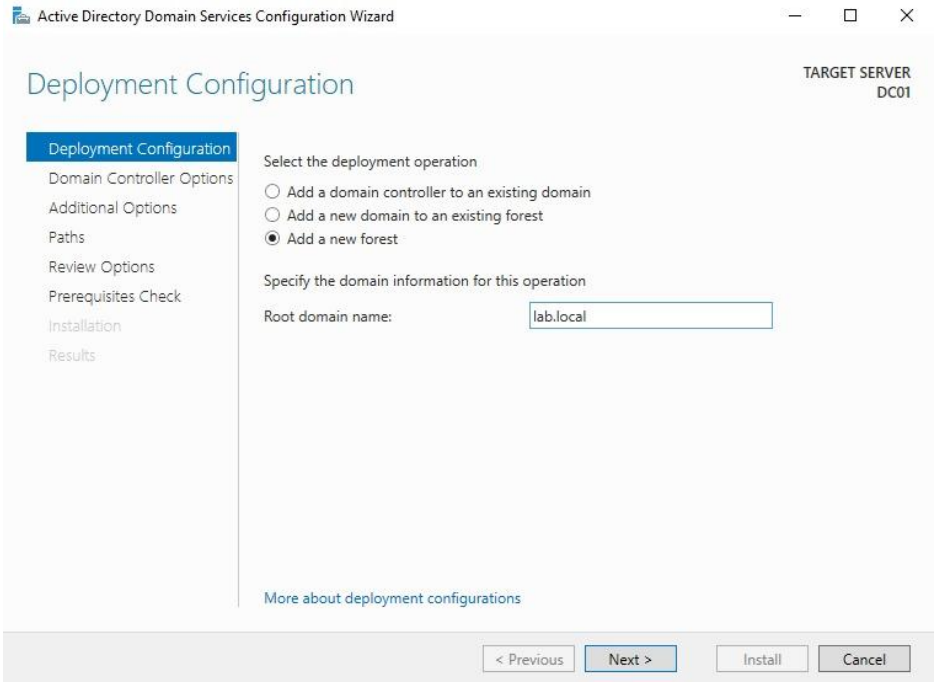


Figure 30 - Creation of a new forest with the lab.local domain.

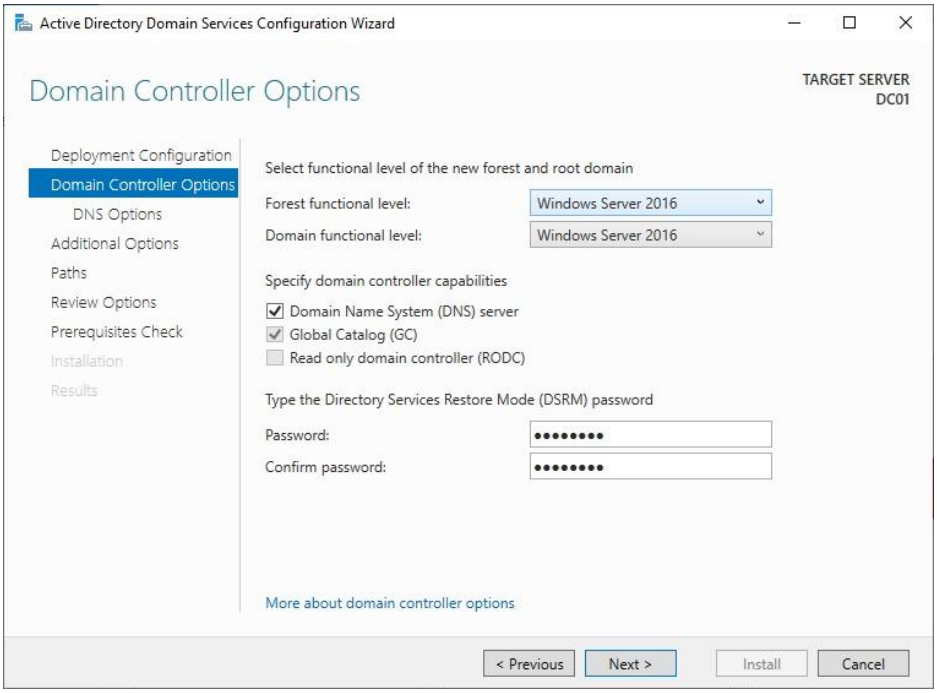


Figure 31 - Functional levels and DNS and Global Catalog options.

Functional level of 2016 is a domain and forest environment. The currently installed version of OS is Windows Server 2019. The DSRM password is masked and thus is not presented in this report.

4.7 Domain controller validation

Get-ADDomainController command finds out the details DC01.lab.local, IP 192.168.10.10, Global Catalog and Writeable Domain Controller. The OperationMasterRoles property tells about the FSMO roles.

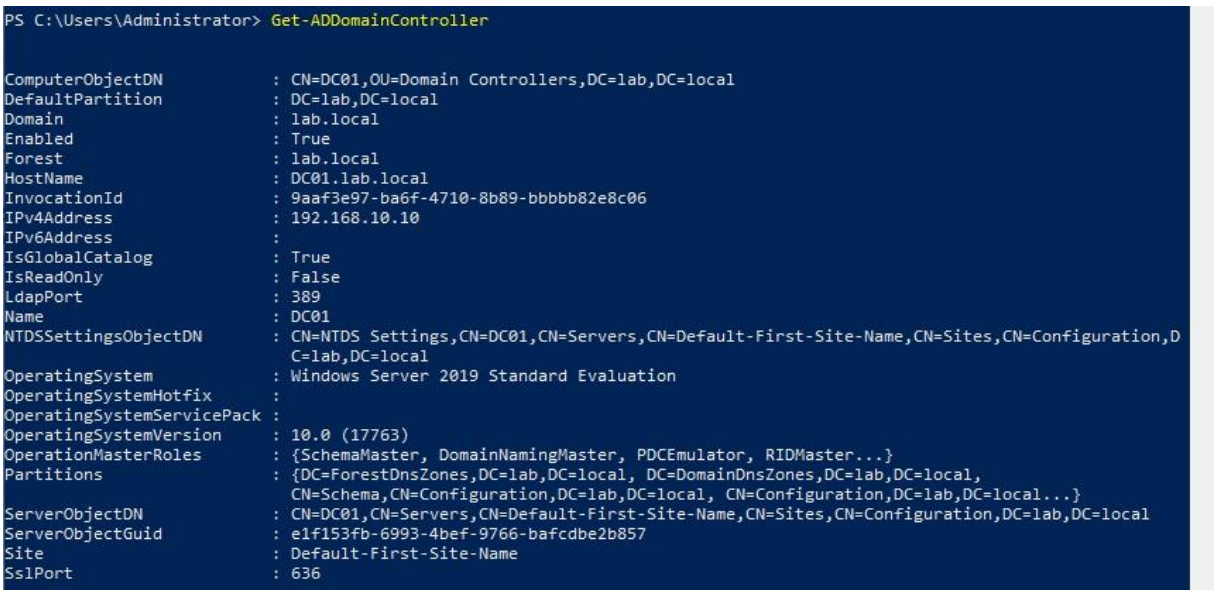


Figure 32 - DC01 identified as the domain controller and FSMO role holder.

The Get-ADDomain command returns DNS root as lab.local, NetBIOS Name as LAB and Domain mode Windows2016Domain. These outputs together prove the promotion of the server and the presence of the domain.

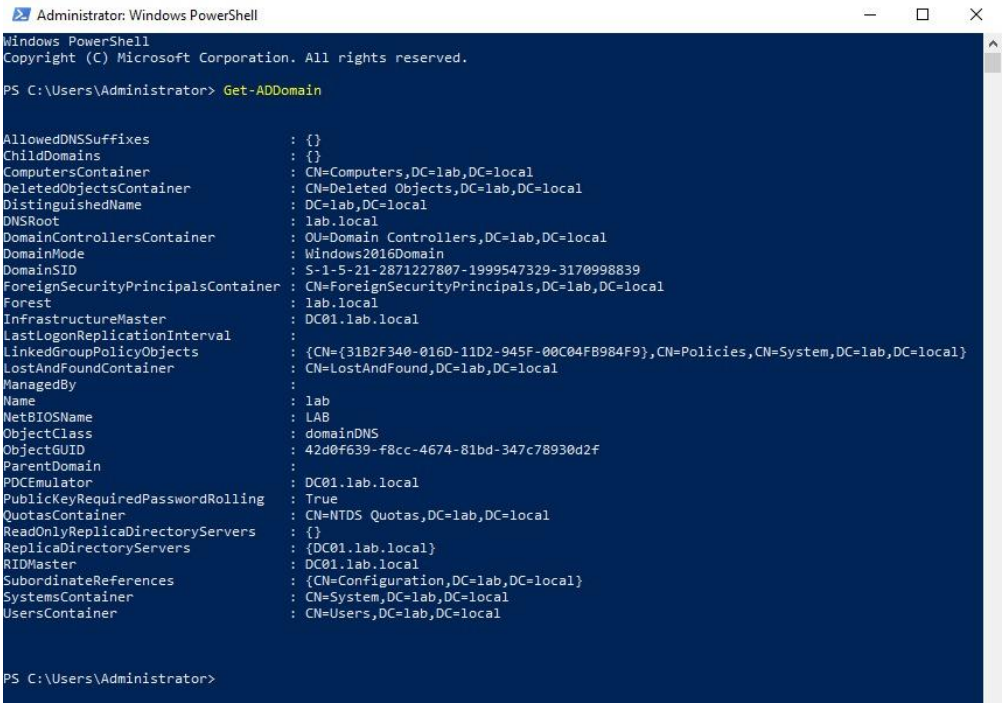


Figure 33 - Domain properties obtained using `Get-ADDomain`.

4.8 Environment generation with BadBlood

BadBlood creates the users, groups, computers, organisational units, and permissions needed for Active Directory training [2]. The first enumeration reveals 3 users, 48 groups, 1 computer, and 1 organisational unit.

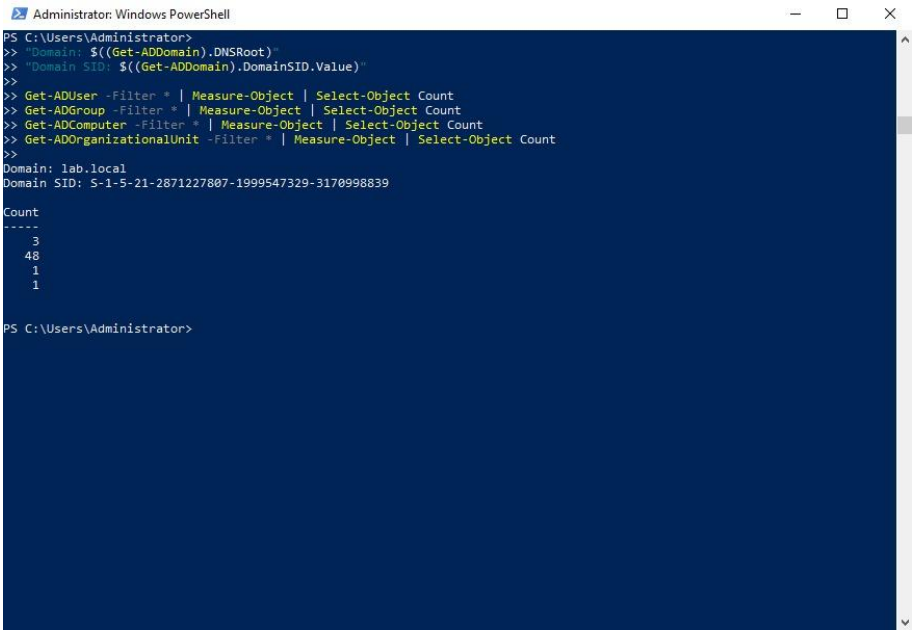


Figure 34 - Domain identification and initial object counts.

BadBlood startup screen displays the number of 100 users, 30 groups, and 10 computers. This screen captures the requested numbers and waits for approval of execution; this is not the final count.

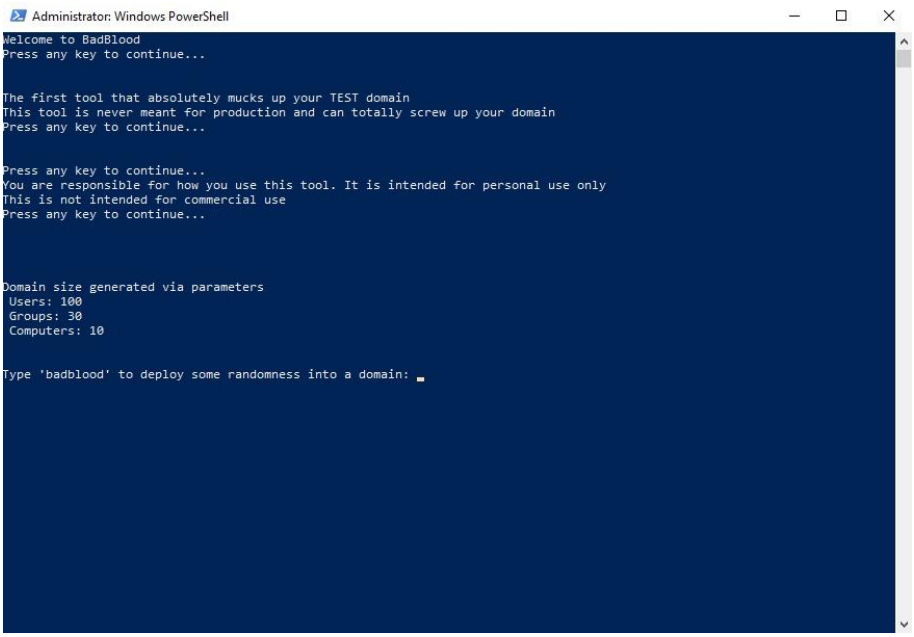


Figure 35 - BadBlood parameters displayed before confirmation.

Changes in domain object counts

Another record contains 93 users, 77 groups, 10 computers and 223 organizational units. In the same screenshot one can see the Running state of the DNS and NTDS services.

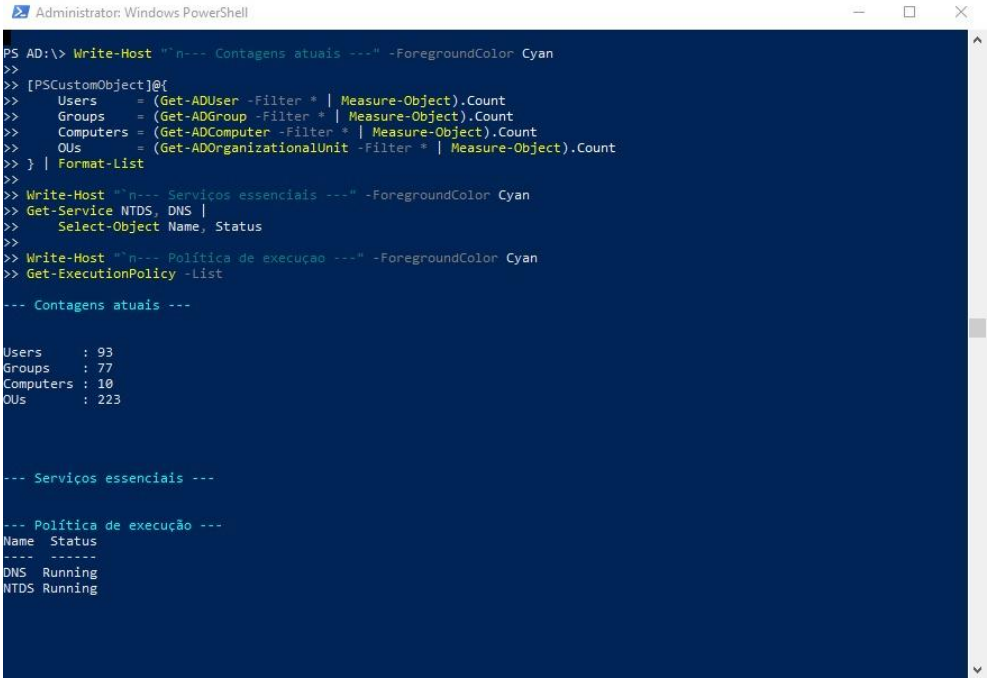


Figure 36 - Later object counts and essential service status.

Object type	Initial state	Later state	Change
Users	3	93	+90
Groups	48	77	+29
Computers	1	10	+9
Organisational units	1	223	+222

These figures are comparing the observed inventories of two; they cannot be taken to mean the number of items that have been created by the BadBlood execution once. Specifically, the subsequent total of 93 users does not indicate that all 100 users indicated in the parameter list have been created.

This rise in number of objects and associations is in line with creation of an advanced training ground. Validation for the full execution requires the BadBlood completion log and any errors observed. The 223 organisation units also provide a bigger area for delegation and inheritance of permissions.

4.9 Data collection with SharpHound

The executed command is .\SharpHound.exe --CollectionMethods Default, using the path C:\Lab\SharpHound. The collector discovers lab.local and enumerates. There is one collection with 301 objects and one collection with 651 objects; those numbers refer to different sessions and not to the directories' object count.

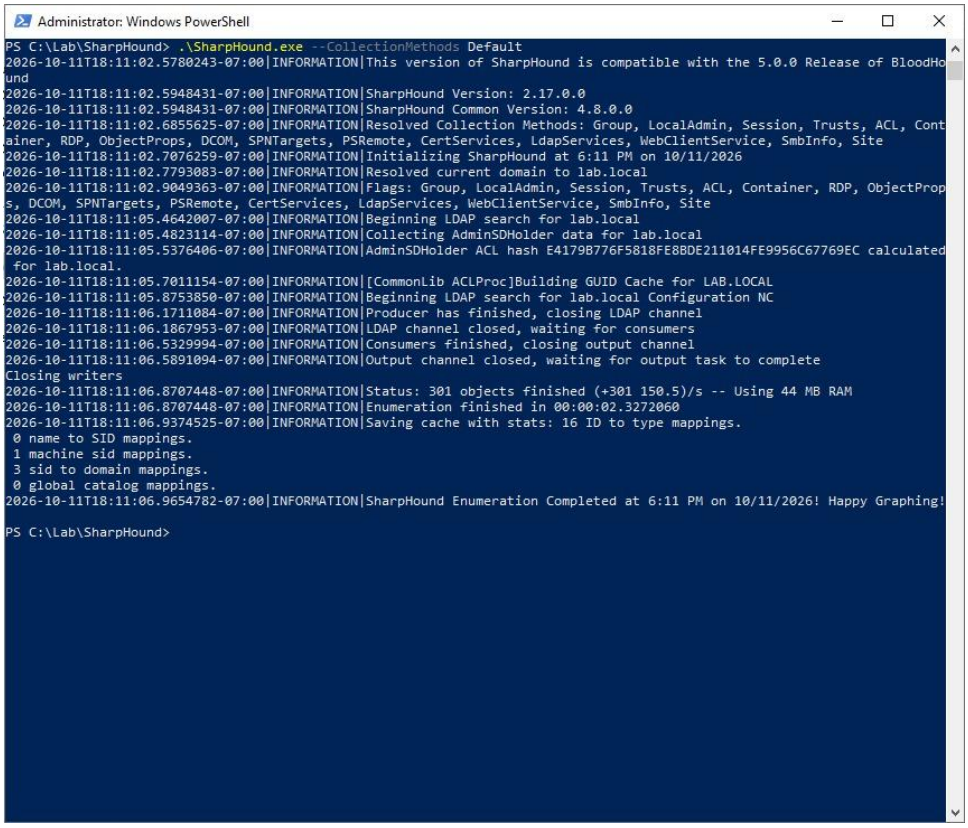


Figure 37 - First completed collection with 301 objects processed.

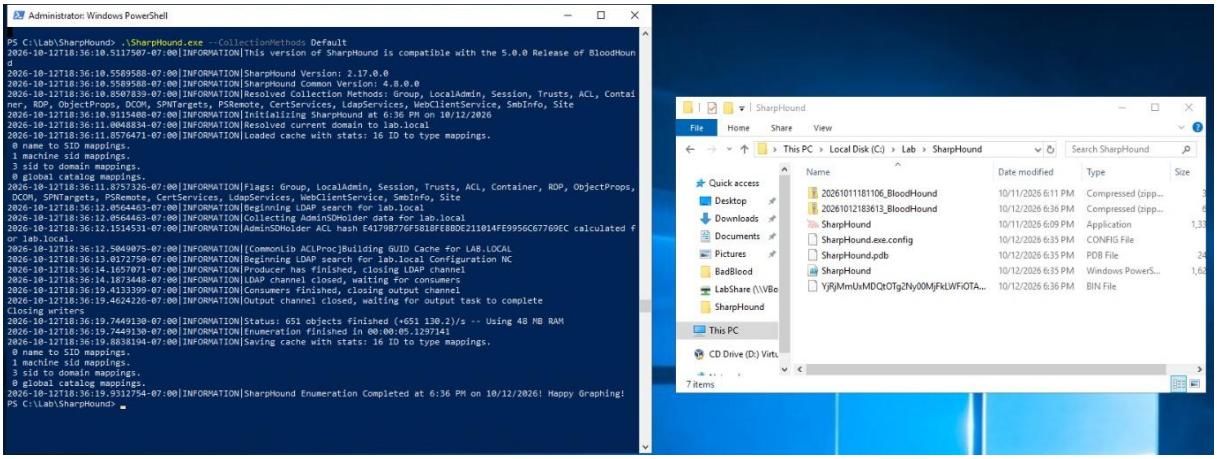


Figure 38 - Later collection with 651 objects and ZIP output files.

Group, Local Admin, Sessions, Trusts, ACL and Object Properties are some of the methods used in the log. The creation of the ZIP shows that a collection package was created; the existence of the same in BloodHound is proved in the following steps.

4.10 Running BloodHound Community Edition

T Linux workstation has Docker version 26.1.3 and Docker Compose version 2.27.1. When we execute sudo docker compose up -d, volumes are created, and the application, application database, and graph database services are started [3].

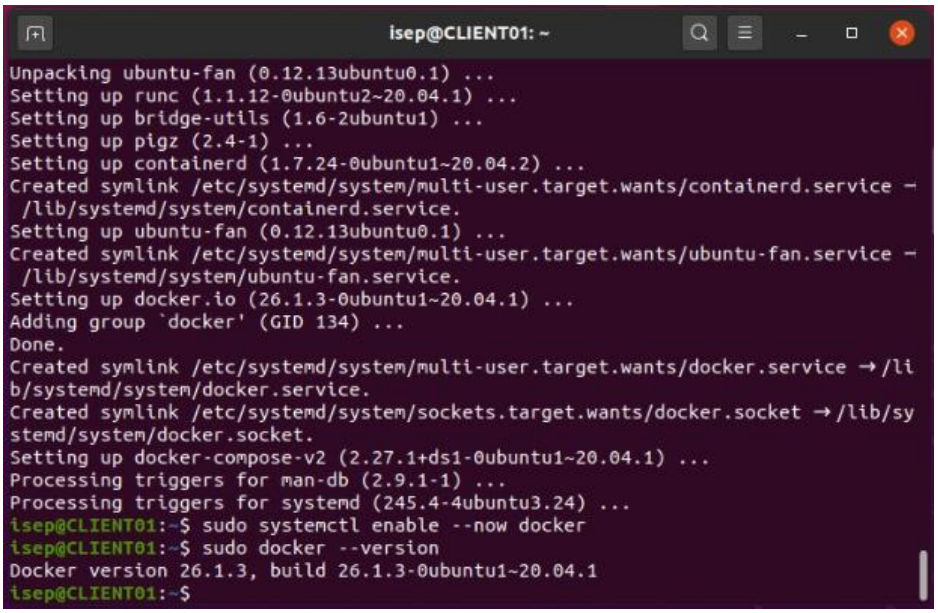


Figure 39 - Docker installation and verification on the Linux workstation.

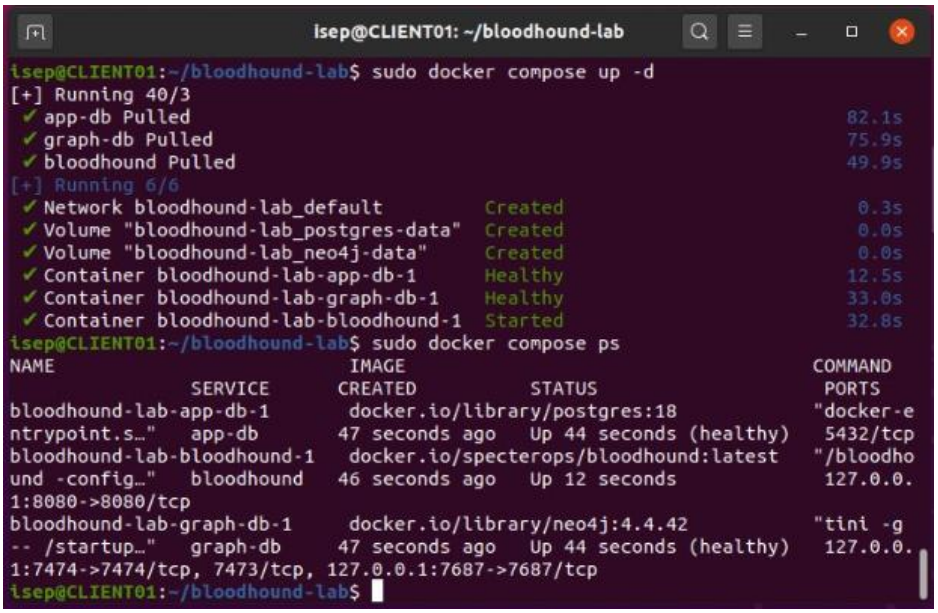


Figure 40 - Service startup and status checks with Docker Compose.

App-db and graph-db are shown healthy and bloodhound is running using docker-compose ps command. Graph database image visible is neo4j:4.4.42. App is accessible at 127.0.0.1:8080, while Neo4j services are accessible at 127.0.0.1:7474 and 127.0.0.1:7687.

4.11 Neo4j configuration and access

The logs contain Neo4j Desktop 1.6.3, a template for BloodHound-Lab creation with version 4.4.0 and a Neo4j Browser connected with Bolt to localhost:7688. These log data prove the usage of Neo4j tools [4].

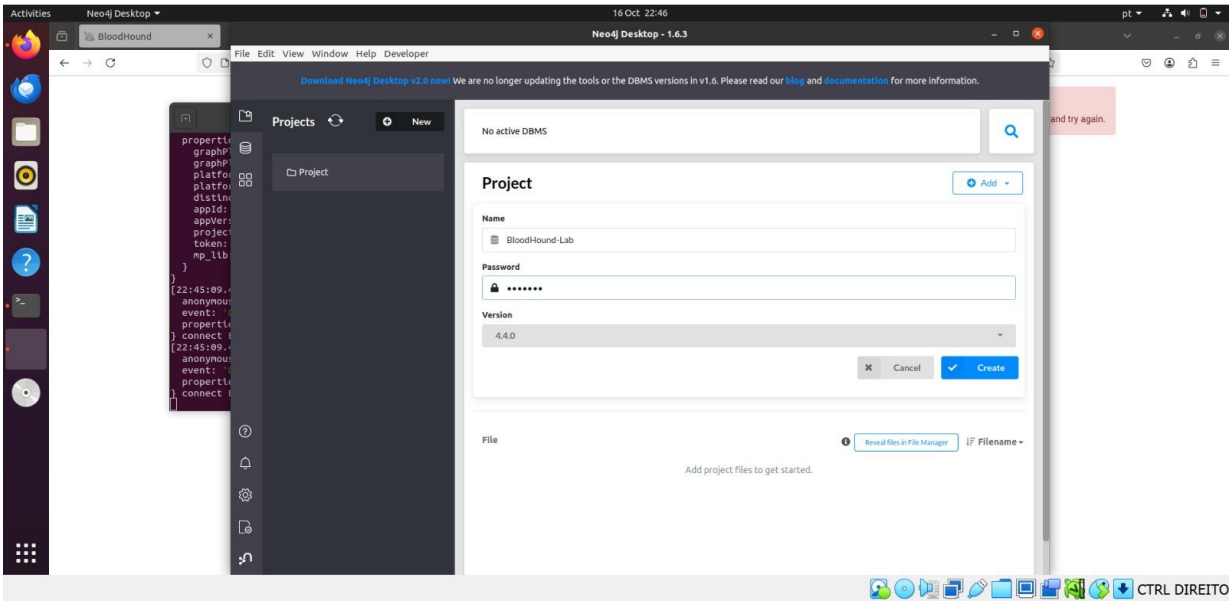


Figure 41 - BloodHound Lab creation form in Neo4j Desktop.

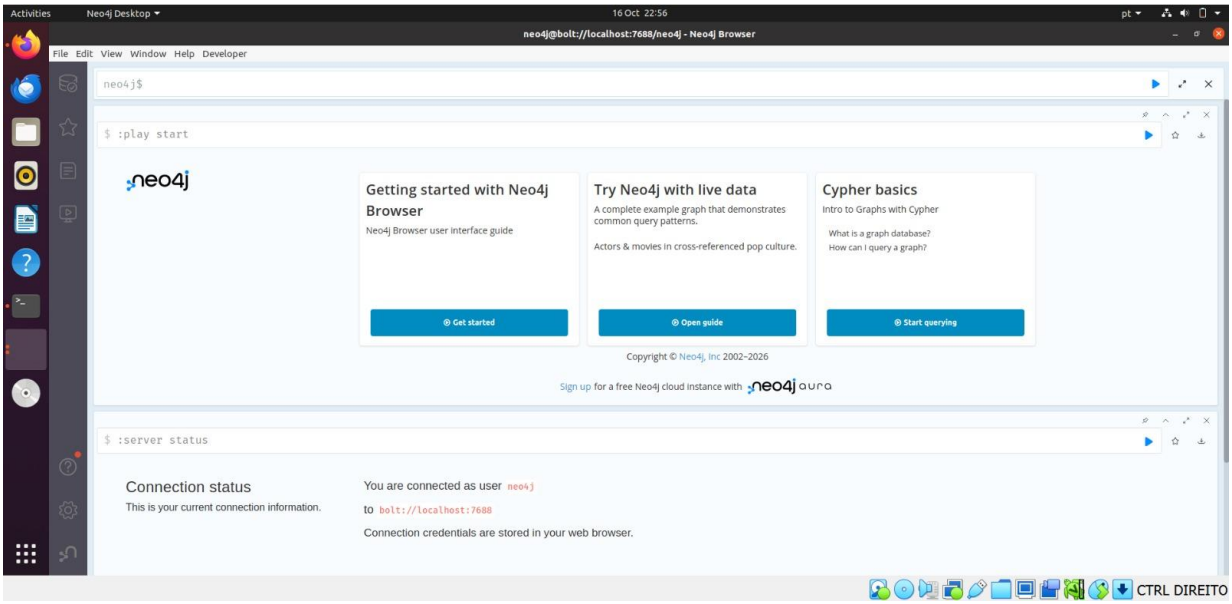


Figure 42 - Neo4j Browser session connected as user neo4j.

Port 7688 in this case is different from the port 7687 published by the graph-db container. The assumption cannot be made that the Database which is used in BloodHound CE is the Desktop project. It is shown that results are being uploaded in BloodHound.

4.12 Data import and exploration

Upload fast can accept both JSON and ZIP files having data collected by collectors. Below is a figure showing the 20261011181106_BloodHound.zip file with 100 percent completeness and confirmation of successful upload.

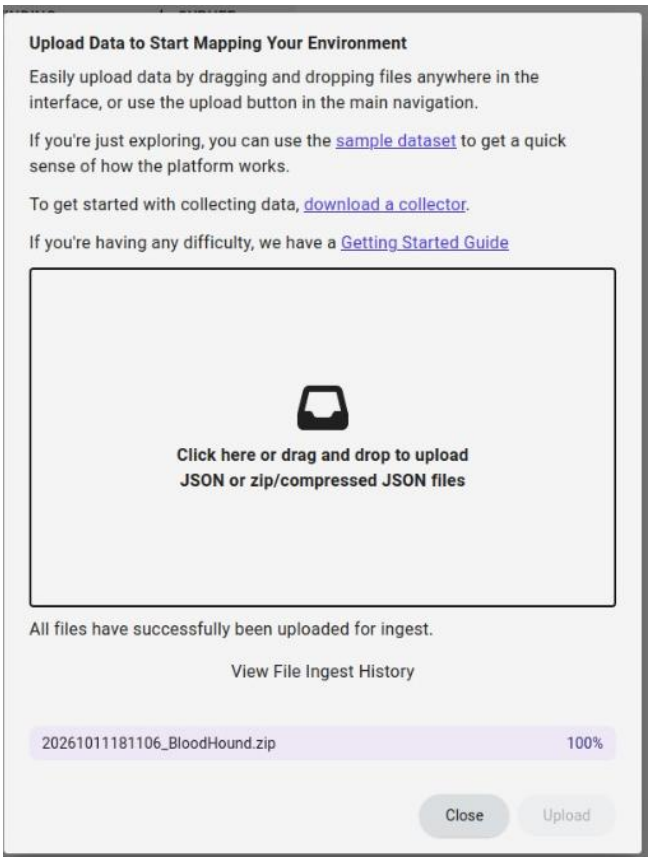


Figure 43 - SharpHound package uploaded for ingestion in BloodHound CE.

A completed upload alone does not prove that ingestion has finished. The subsequent queries of the LAB.LOCAL domain and Administrator relationships provide evidence that Active Directory data is available for graph analysis.

The uploaded ZIP filename corresponds to the collection reporting 301 objects processed. A later collection processed 651 objects, but the screenshots do not unambiguously identify the import of that second package. Graph counters are therefore not automatically equated with the later BadBlood inventory.

Reading the following figures

The following pages use landscape orientation to keep node names, relationship labels and BloodHound properties legible. The MemberOf and AdminTo labels are retained for direct comparison with the tool.

4.13 Domain properties in BloodHound

The LAB.LOCAL node is captured and categorized under Tier Zero. The panel displays that the functional level is 2016, the Machine Account Quota is 10, and Lockout Threshold is 0. The reason for the selection of these values is that they represent the captured state.

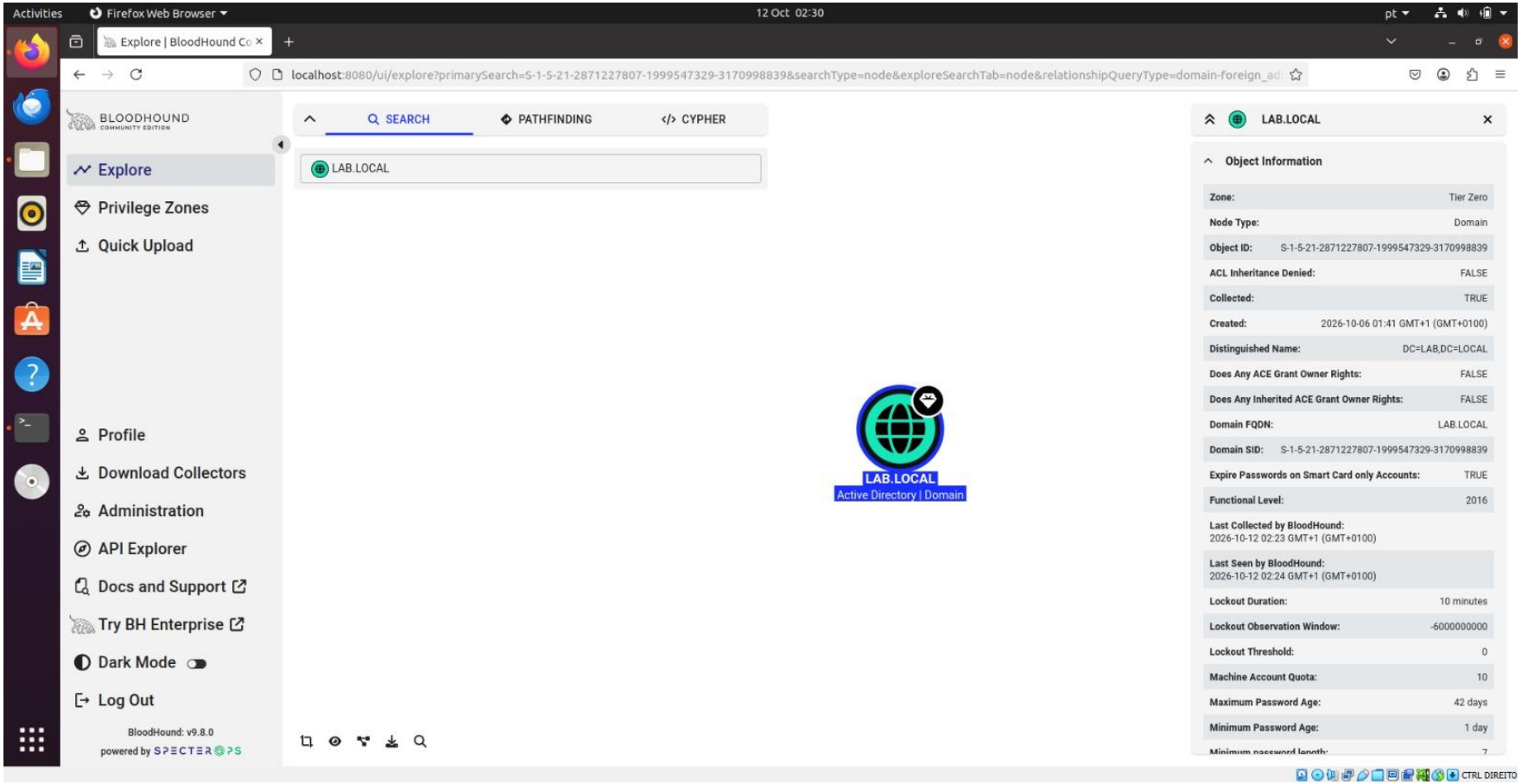


Figure 44 - Properties of the LAB LOCAL node in BloodHound.

4.14 Administrator account memberships

Member Of shows 11 members that include Domain Admins, Enterprise Admins, and Schema Admins. Membership does not imply a vulnerability on its own; this is where the privileges of the groups come into play to show the extent of the administrative capabilities of the account [5].

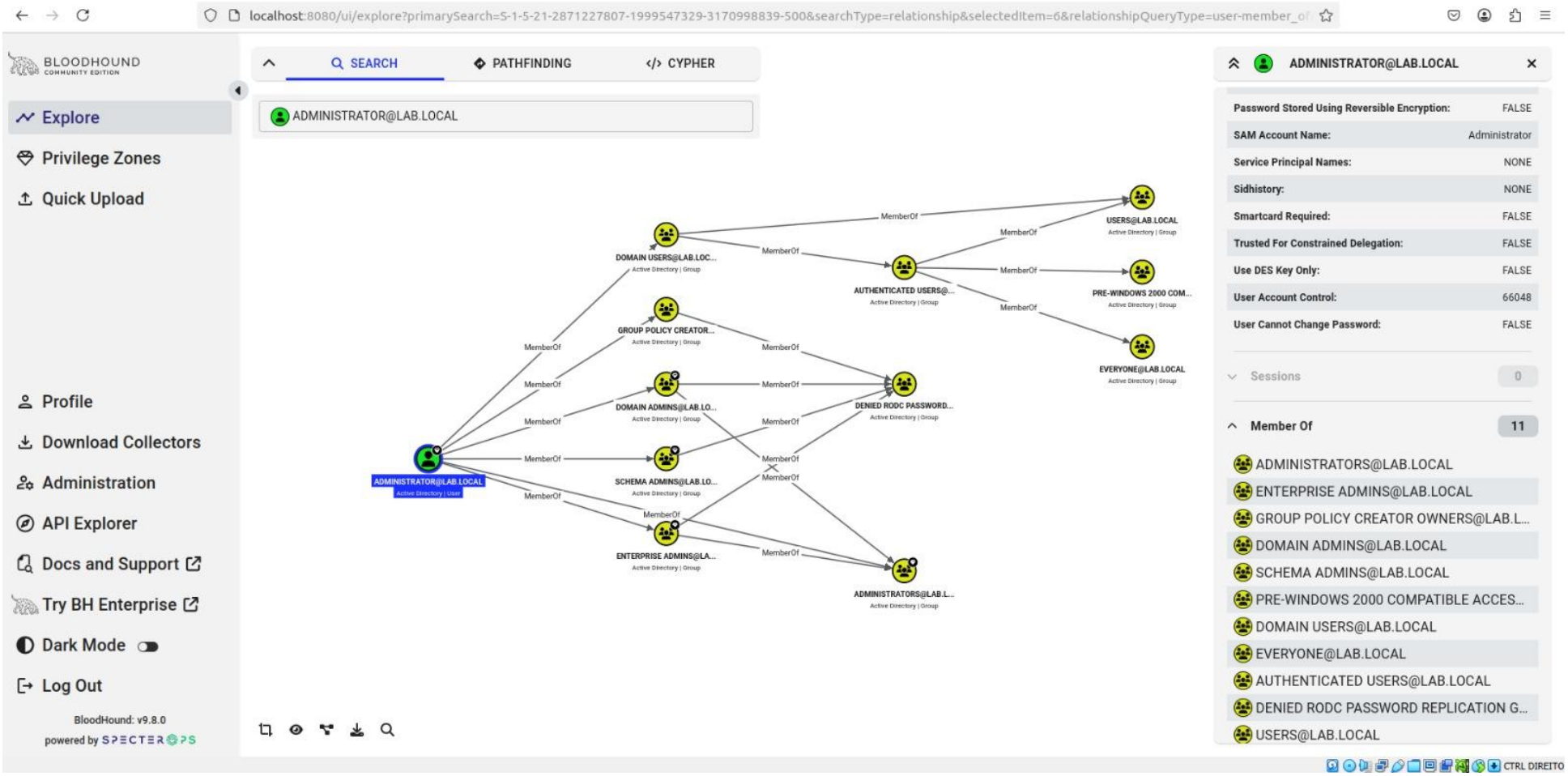


Figure 45 - Administrator memberships and group nesting.

4.15 Privilege path to DC01

Below is an example of two paths: Administrator → MemberOf → Domain Admins → AdminTo → DC01 and Administrator → MemberOf → Enterprise Admins → AdminTo → DC01. The term "AdminTo" indicates administrative access to the target machine [6]. This path starts off assuming that the administrator user has been compromised.

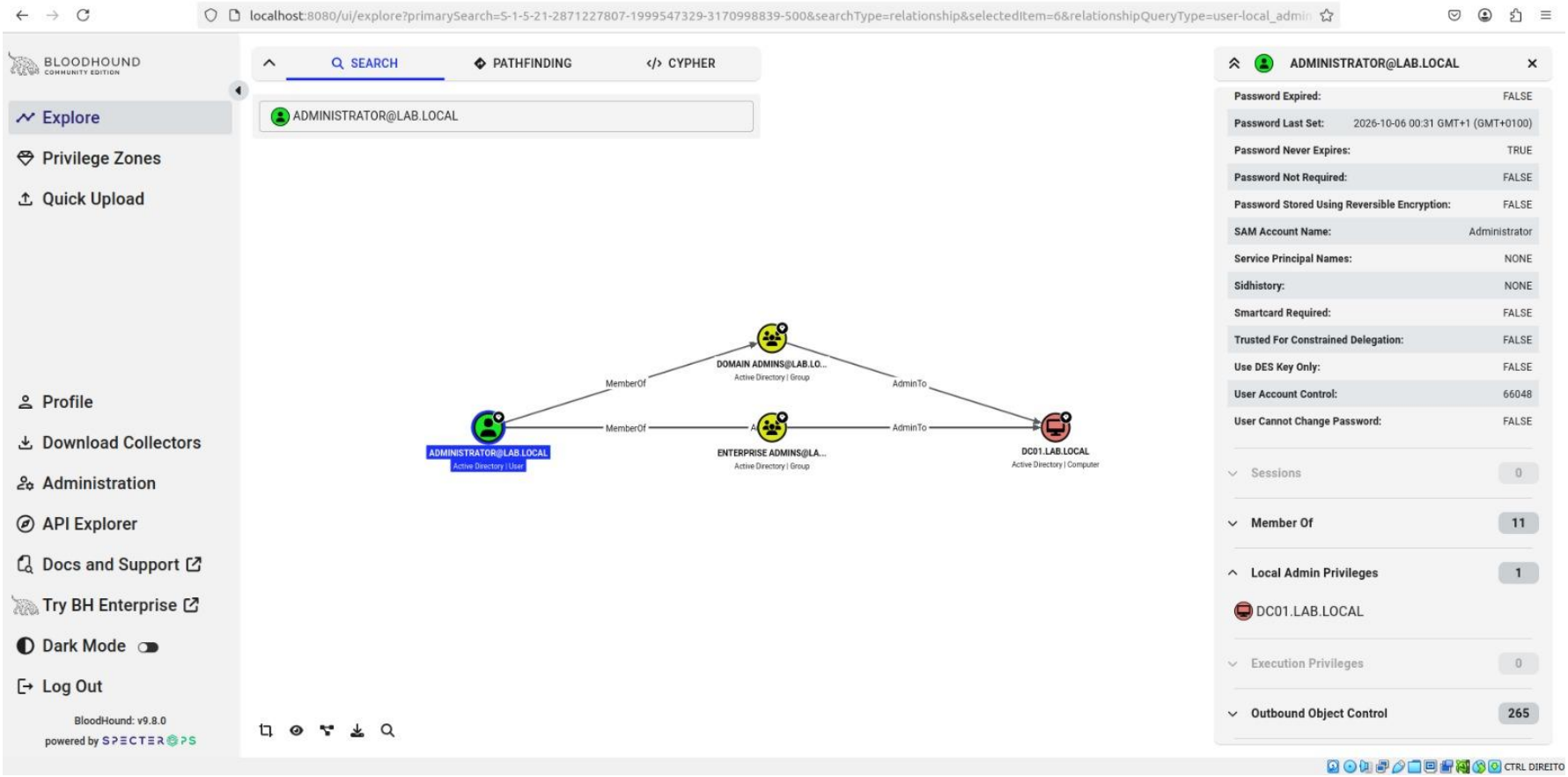


Figure 46 - Paths from Administrator to administrative control of DC01.

4.16 Scope of the Domain Admins group

Domain Admins group has 1 member, local administrative rights to 1 machine, 3 inbound and 614 outbound relationships, which include Owns and WriteOwner access for several objects. These figures do not imply 614 separate risks and also do not prove that an ordinary user is able to control the Domain Admins group.

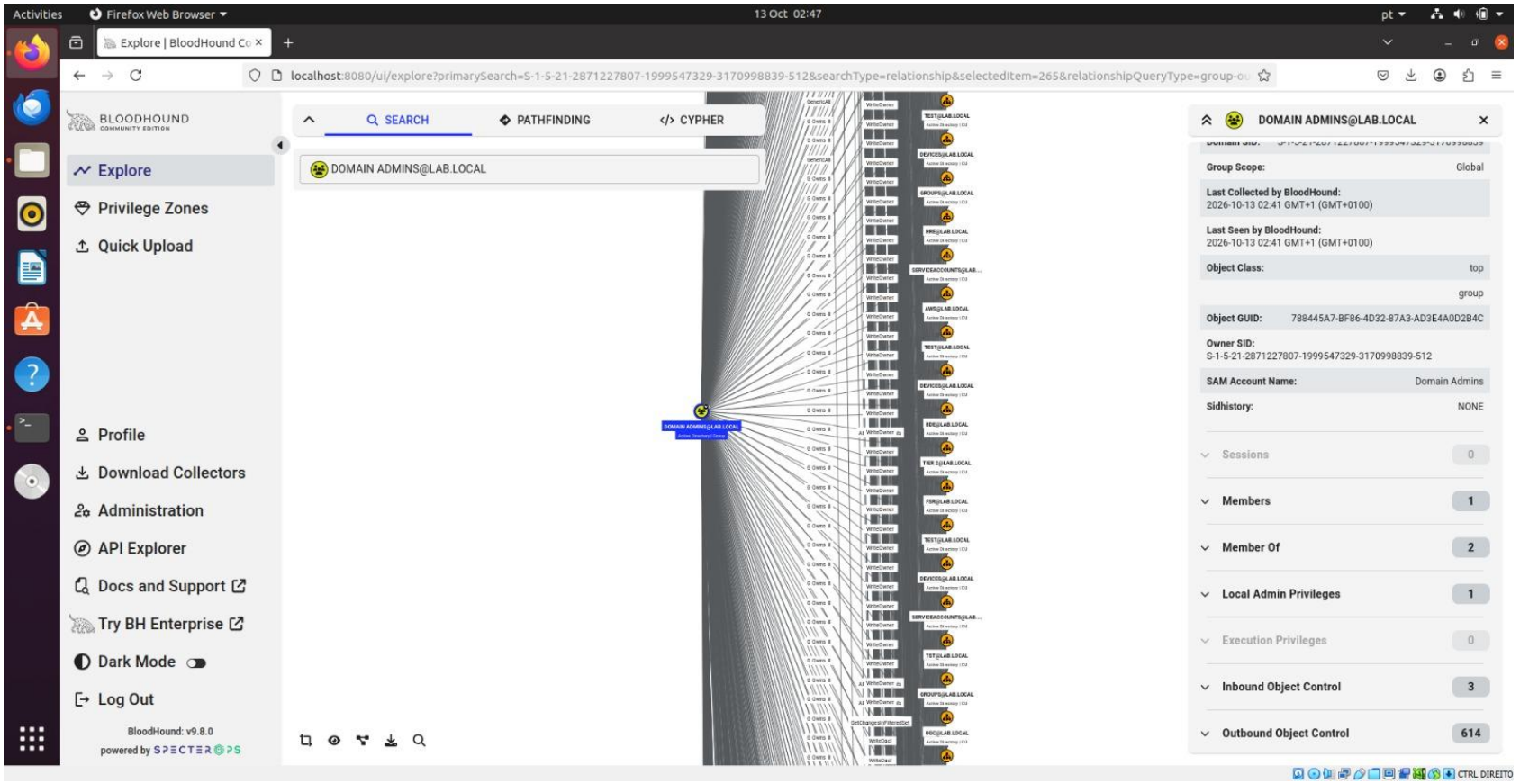


Figure 47 - Domain Admins group relationships and counters.

4.17 Attack vector analysis

4.17.1 Observed path and starting condition

Graph analysis can help examine a situation where the compromised identity has access to administrative privileges within a domain. It is assumed that initial control is attained through access to the Administrator account. This is an example of scenario-based impact analysis rather than a proven one; there is no evidence for password recovery, ticket theft, or session hijacking.

The compromised identity becomes connected via MemberOf associations to Domain Admins and Enterprise Admins. These become connected to DC01 via AdminTo associations. The possible impact is the use of the existing administrative privileges over the domain controller, if there is successful authentication and connectivity [5, 6].

4.17.2 Potential exploitation in a test environment

Verifying this hypothesis in a lab will entail authenticating the test session as the source identity, validating the proper group memberships as well as validating the minimal administration on the target while retaining logs of the authentication and the result of the administrative process. Remote administrative access would make this possible if the related service was accessible and available.

HackTricks lists Active Directory relationship analysis and permission abuse among the investigation fields [7]. In this case, the escalatory analysis should begin from an unprivileged account to find a verifiable path to a sensitive resource. The outbound relationships of the Domain Admins do not satisfy this criterion.

4.17.3 Relationship with Kerberos

Kerberos can validate a session of the exploited identity through tickets obtained from the KDC. However, the diagram does not provide tickets, SPN of the attacked service account, TGS requests obtained, password reset information or exploit result. It cannot be determined whether Kerberoasting, AS REP roasting, Pass the Ticket or Golden Ticket execution is done. The output of the demonstration is the analysis of authorisation and privilege escalation.

4.17.4 Evidence required to complete validation

For the validation of the attack, it is required to correlate the initial identity, every relationship in the chain, the executed action and the resultant access or change in the privilege status. For the privilege escalation from a regular account, it is required to prove the improper permission to

breach privilege boundary. Without such evidence, the appropriate classification of the vulnerability would be Potential Path High Impact No Exploit.

4.18 Risks and mitigation measures

The following recommendations arise from the observed configurations and path analysis.

Observation	Implication	Proposed measure
Administrator belongs to domain administration groups	Account compromise may provide administrative access to DC01.	Separate administrative and everyday accounts; restrict sign-in locations and review privileged memberships.
Password Never Expires is TRUE for Administrator	An exposed credential may remain valid for longer.	Review account policy, enforce strong passwords and manage rotation in line with administrative use.
Lockout Threshold is 0 on the domain node	The collected policy does not define lockout after failed attempts.	Define an appropriate policy and monitor authentication failures, considering the risk of malicious lockouts.
Machine Account Quota is 10	Review who can create computer accounts and under which conditions.	Restrict computer creation to authorised identities and audit new accounts.
Multiple Owns and WriteOwner relationships	Inappropriate delegation may extend an identity's reach.	Review ACLs and owners from low-privilege accounts; remove unnecessary delegation.
DNS for lab.local also returns 10.0.2.15	Internal network clients may receive an address without a suitable route.	Review DNS registration on the NAT interface and validate names and services from the LAB segment.
Updates not evidenced	The requirement to install all patches has not been validated.	Complete updates, restart if needed and retain the history and final status.

Following each correction, the process must be repeated and the path checked in BloodHound, as well as whether any effective permissions have been altered in Active Directory. Any change to the graph will have meaning if the data represents the current directory structure.

4.19 Results against the exercise requirements

Requirement	Evidence and assessment
1 Obtain Windows Server 2019	Windows Server 2019 Standard Evaluation is running. The image source and download process are not demonstrated.
2 Install on a virtual machine	VirtualBox is identified in system properties. Server installation and operation are demonstrated.
3 Install all patches	Not validated. The initial record shows Never in the update fields.
4 Promote to Domain Controller	Demonstrated by the wizards, Get-ADDomainController and Get-ADDomain.
5 Use BadBlood	Startup, parameters and object growth are demonstrated. Full completion of a run is not confirmed by a final log.
6 Run BloodHound	Demonstrated by service startup, the CE 9.8.0 interface and graph queries.
7 Install Neo4j Desktop and load results	Desktop and Browser are demonstrated. ZIP upload and object queries show data in BloodHound. It is not established that the Desktop instance is the application's database.
8 Identify a vector and discuss exploitation	Administrator → privileged groups → DC01 path identified. Exploitation is discussed as a hypothesis; escalation from a standard account and a Kerberos attack are not demonstrated.

4.19.1 Experimental limitations

The entries represent different environment states. The imported ZIP file is unique, although there is no entire timeline showing that all the numbers, collections and searches belong to the same experiment. Time and time zones can also differ, so filename is not taken into consideration as an experimental timeline.

VM creation on Windows 11 is the preparation stage entry and not evidence that the machine belongs to the domain. In turn, the screen shot of LAB\Administrator proves the login context, but does not show an attack or replace the authentication entry.

4.20 Conclusion

Active Directory domain was established on Windows Server 2019, where DC01 provided domain and DNS services for lab.local. Network settings, administrative queries and service status support the functionality of the main laboratory components.

BadBlood files and counts demonstrate directory growth. SharpHound created collection packages, and BloodHound CE presented the domain and its privilege relationship. The analysis showed the way how access from the Administrator to administration of DC01 through Domain Admins and Enterprise Admins is possible.

The main security consideration in this case is a better understanding of consequences of the compromised privileged account. The described path represents an existing right of administrative access and not an escalation. To prove privilege escalation, the analysis should be done from the less privileged account and prove a permission which crosses a security boundary. For Kerberos attack more evidence is required depending on the tickets and methods used.

Completion of laboratory validation requires update proof, DNS registration check and link between collections and domain status. The security considerations are reduction of privileged identity exposure, delegation review and repeat of the analysis with corrections.

4.20.1 Summary of confirmed results

Result	Observed value
Domain	lab.local
Controller	DC01.lab.local at 192.168.10.10
Domain functional level	Windows Server 2016
Objects in the later inventory	93 users; 77 groups; 10 computers; 223 organisational units
Essential services	DNS and NTDS running
SharpHound collections	301 and 651 objects processed in separate runs
Privilege path	Administrator → Domain Admins or Enterprise Admins → DC01
Completed exploitation	Not demonstrated

5 PL03.ex1 - TACACS+

Environment	Ubuntu Server 26.04.1 LTS on Oracle VirtualBox
Server	tac_plus (TACACS+)
Date	October 2026

5.1 Objective

The aim of this assignment is to set up a TACACS+ server on Linux VM, to create users of various profiles, to create authentication traffic, and finally to illustrate how the shared secret can be recovered from that traffic. This assignment ends with a discussion on the major security aspects of this protocol.

5.2 Server installation and preparation

The Ubuntu Server VM was set up using Oracle VirtualBox. As the TACACS+ server application was not present in the repository, the tac_plus server was built from the source code. Dependencies such as PAM, build tools, flex, and bison were installed.

Main commands used:

```
sudo apt update

sudo apt install build-essential git libpam0g-dev libwrap0-dev flex bison -y

./configure --without-libwrap CFLAGS="-g -O2 -std=gnu99"

make

sudo make install

sudo ldconfig
```

On installation, the executable was located at /usr/local/sbin/tac_plus. The server was then started using the config file which was located at /usr/local/etc/tac_plus.conf using TCP Port 49.

```
sudo tac_plus -C /usr/local/etc/tac_plus.conf

sudo ss -lntp | grep :49
```

5.3 TACACS+ configuration

The common secret password MinhaChaveTACACS123 was defined, and three functional groups were created: standard, accountant, and admin.

```
key = MinhaChaveTACACS123

group = standard {
    default service = permit
}

group = accountant {
    default service = permit
}

group = admin {
    default service = permit
}
```

Also, TACACS+ users were defined for testing purposes. Users named Bob and Alice were allocated into the standard functional group, while Madeleine and Jake were put in the accountant and admin groups correspondingly. Also, user John was added to the standard group to finalize the laboratory setup.

5.4 Linux system users and groups

In order to satisfy the need of creating user accounts directly in the machine, the following Linux accounts were created: bob, alice, john, madeleine, and jake. Bob, Alice, and John were added to the standard group while Madeleine was added to the accountant group and Jake to the admin group.

```
andre@tacacslab:~/tac_plus/tacacs-F4.0.4.28$ id bob
id alice
id john
id madeleine
id jake
uid=1004(bob) gid=1004(bob) groups=1004(bob),100(users),1001(standard)
uid=1005(alice) gid=1005(alice) groups=1005(alice),100(users),1001(standard)
uid=1006(john) gid=1006(john) groups=1006(john),100(users),1001(standard)
uid=1007(madeleine) gid=1007(madeleine) groups=1007(madeleine),100(users),1002(accountant)
uid=1008(jake) gid=1008(jake) groups=1008(jake),100(users),1003(admin)
andre@tacacslab:~/tac_plus/tacacs-F4.0.4.28$
```

Figure 48 - Verification of the Linux users and their respective groups using the id command

5.5 Authentication test and traffic capture

The Perl module Authen::TacacsPlus was used to perform a test authentication with the user Bob. The test returned Authentication successful, confirming that the server was operating correctly.

```
sudo tcpdump -i lo -w ~/tacacs.pcap tcp port 49
```

The tacacs.pcap file was opened in Wireshark and analysed using the following filter:

```
tcp.port == 49
```

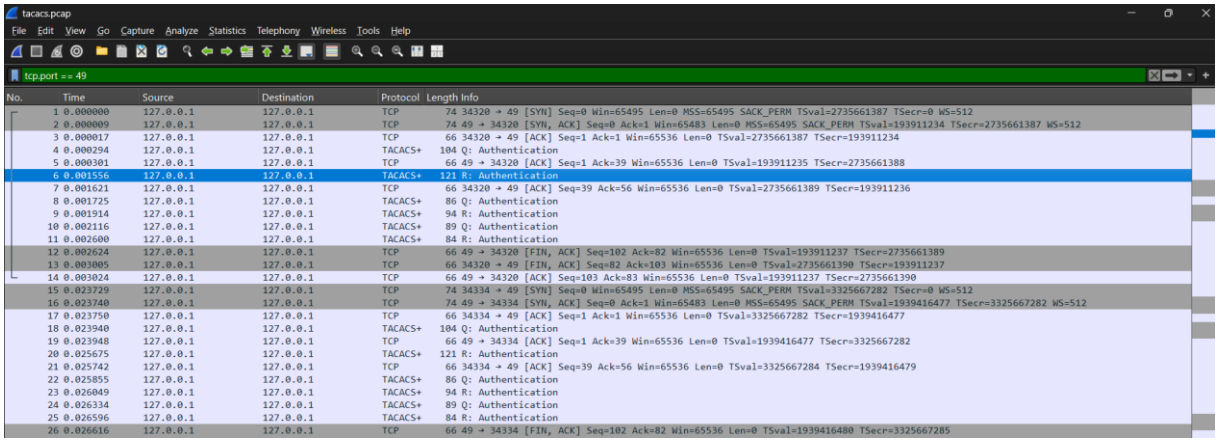


Figure 49 - Overview of the captured TACACS+ traffic filtered by TCP port 49

5.6 TACACS+ packet analysis

In the authentication request, the TACACS+ header can be inspected; version, message type, sequence number, Session ID, flags, and payload length can be analyzed here. As for the message content, Wireshark detects it as Encrypted Request; hence, the authentication information is encrypted and cannot be viewed as clear text.

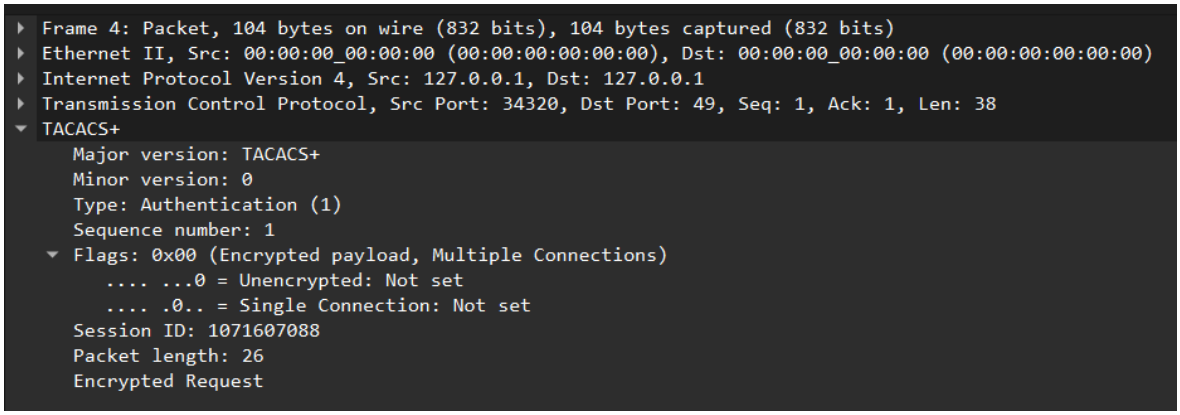


Figure 50 - TACACS+ authentication request (Sequence number 1) with an encrypted payload

The server reply also has the same Session ID 1071607088; therefore, the request and reply belong to the same session. Sequence number equals 2 now, and the content is shown as Encrypted Reply.

```
▸ Frame 6: Packet, 121 bytes on wire (968 bits), 121 bytes captured (968 bits)
▸ Ethernet II, Src: 00:00:00_00:00:00 (00:00:00:00:00:00), Dst: 00:00:00_00:00:00 (00:00:00:00:00:00)
▸ Internet Protocol Version 4, Src: 127.0.0.1, Dst: 127.0.0.1
▸ Transmission Control Protocol, Src Port: 49, Dst Port: 34320, Seq: 1, Ack: 39, Len: 55
▾ TACACS+
    Major version: TACACS+
    Minor version: 0
    Type: Authentication (1)
    Sequence number: 2
  ▾ Flags: 0x00 (Encrypted payload, Multiple Connections)
      .... ...0 = Unencrypted: Not set
      .... .0.. = Single Connection: Not set
    Session ID: 1071607088
    Packet length: 43
    Encrypted Reply
```

Figure 51 - TACACS+ authentication response (Sequence number 2) from the same session

5.7 Extraction and recovery of the shared secret

To test the strength of the shared secret, the capture was converted to a Hashcat-supported format using hcxpcapngtool:

```
hcxpcapngtool --tacacs-plus=tacacs.16100 ~/tacacs.pcap

sort -u tacacs.16100 > tacacs_unique.16100

hashcat -m 16100 -a 0 tacacs_unique.16100 ~/keys.txt
```

The attack finished with Status: Cracked and Recovered: 6/6 (100%). The recovered key was MinhaChaveTACACS123, demonstrating that a predictable shared secret can be discovered through an offline attack when an attacker has a valid traffic capture.

```
$tacacs-plus$0$3fdf6d30$147ecf103cbadad43ad782e11732d8b597a7550eb9b196104cc7$c001:MinhaChaveTACACS123
$tacacs-plus$0$3fdf6d30$b671cb4579fe3c7ca86a239b88338afc5105ca7822106884 3bf6ccfbc52bb1f38a96f4691a552034ceab88$c002:MinhaChaveTACACS123
$tacacs-plus$0$3fdf6d30$0cabc3490c60fcb4$c003:MinhaChaveTACACS123
$tacacs-plus$0$3fdf6d30$834ce22ba52b9399890638d6beffaea8$c004:MinhaChaveTACACS123
$tacacs-plus$0$3fdf6d30$35ae5a52328f87e4a279f7$c005:MinhaChaveTACACS123
$tacacs-plus$0$3fdf6d30$38f24742beb3$c006:MinhaChaveTACACS123

Session..........: hashcat
Status...........: Cracked
Hash.Mode........: 16100 (TACACS+)
Hash.Target......: tacacs_unique.16100
Time.Started.....: Sun Oct  4 21:49:24 2026 (0 secs)
Time.Estimated...: Sun Oct  4 21:49:24 2026 (0 secs)
Kernel.Feature...: Pure Kernel (password length 0-256 bytes)
Guess.Base.......: File (/home/andre/keys.txt)
Guess.Queue......: 1/1 (100.00%)
Speed.#01........:      776 H/s (0.00ms) @ Accel:1024 Loops:1 Thr:1 Vec:8
Recovered........: 6/6 (100.00%) Digests (total), 6/6 (100.00%) Digests (new), 6/6 (100.00%) Salts
Progress.........: 54/54 (100.00%)
Rejected.........: 0/54 (0.00%)
Restore.Point....: 0/9 (0.00%)
Restore.Sub.#01..: Salt:5 Amplifier:0-1 Iteration:0-1
Candidate.Engine.: Device Generator
Candidates.#01...: admin ->
Hardware.Mon.#01.: Util:  2%
```

Figure 52 - Recovery of the shared secret with Hashcat, mode 16100 (TACACS+)

5.8 Security considerations

The classical method for protecting the message body in TACACS+ relies on a scheme based on a shared secret and the generated keystream derived from MD5. While the payload itself is not being

sent in the clear, the above scheme is not a form of authenticated encryption. The lab has shown that if a shared secret is weak or predictable, the captured packets can be used to brute-force a list of possible keys off-line.

Some of the ways to mitigate this problem include:

- The use of strong, unpredictable shared secrets which differ from device to device or group of devices.
- The avoidance of dictionary passwords, predictable patterns, and key reuse.
- The limitation of access to TCP port 49 via a firewall and/or ACLs, granting access only to authorized management devices.
- Isolation of TACACS+ traffic on a dedicated management network or VLAN.
- The protection of the configuration files, logs, and PCAP captures that might aid offline attacks.
- Regular rotation of the shared secrets and replacing any secret believed to be compromised.
- Monitoring of the authentication service for suspicious activity, including failed authentications.
- Where applicable, the use of additional transport-layer protection schemes, such as TACACS+ with TLS.

5.9 Summary

This assignment made it possible to build up a TACACS+ environment, set up users and profiles, check a genuine authentication, and trace the message exchanges over TCP port 49. The Wireshark output indicated that both request and response payload is shown as an encrypted one, while the Hashcat test proved that a poor-quality shared secret may be cracked off-line based on the traffic capture. Thus, the security of a TACACS+ implementation relies not only on the configuration of the protocol, but also on the shared secret, management network segmentation, and access control to the service.

6 PL04.ex1 - Discretionary Access Control Lists (DACLs)

6.1 Objective

In this experiment, the objective was to deploy and analyse fine-grained access control in Microsoft Active Directory via Discretionary Access Control List (DACL).

Delegation of specific administrative tasks to various organizational groups without assigning all the administrative rights unnecessarily was part of this exercise. The areas involved in the delegation were the ability to reset passwords, managing personal data, managing group memberships, and managing the membership in Domain Admins group.

The following security groups were taken into consideration:

- Finance

- Service Desk

- HR

- SysAdmin

This configuration is based on the Active Directory setup from the previous practical laboratory.

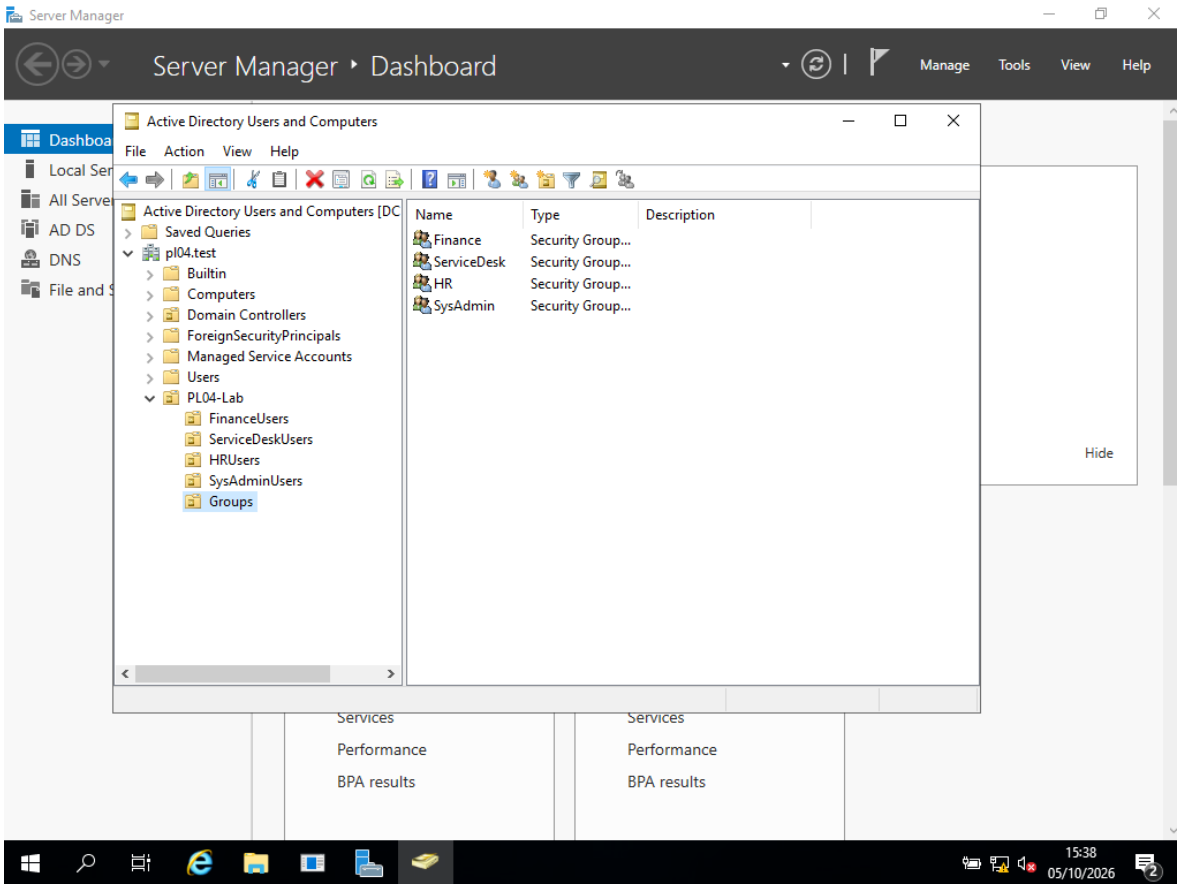


Figure 53 - Security groups used

6.2 Service Desk – Finance Password Reset

The first requirement in terms of delegation was to provide users of the Service Desk group with the ability to reset the passwords of users from the Finance department.

The right for this purpose was delegated to the Service Desk security group in relation to the organizational unit where the Finance user accounts are kept. The delegated rights are related to password management only and not to giving Service Desk staff any administrative rights.

This solution is in line with the principle of least privilege as Service Desk staff get only the rights that are necessary for them to carry out their responsibilities.

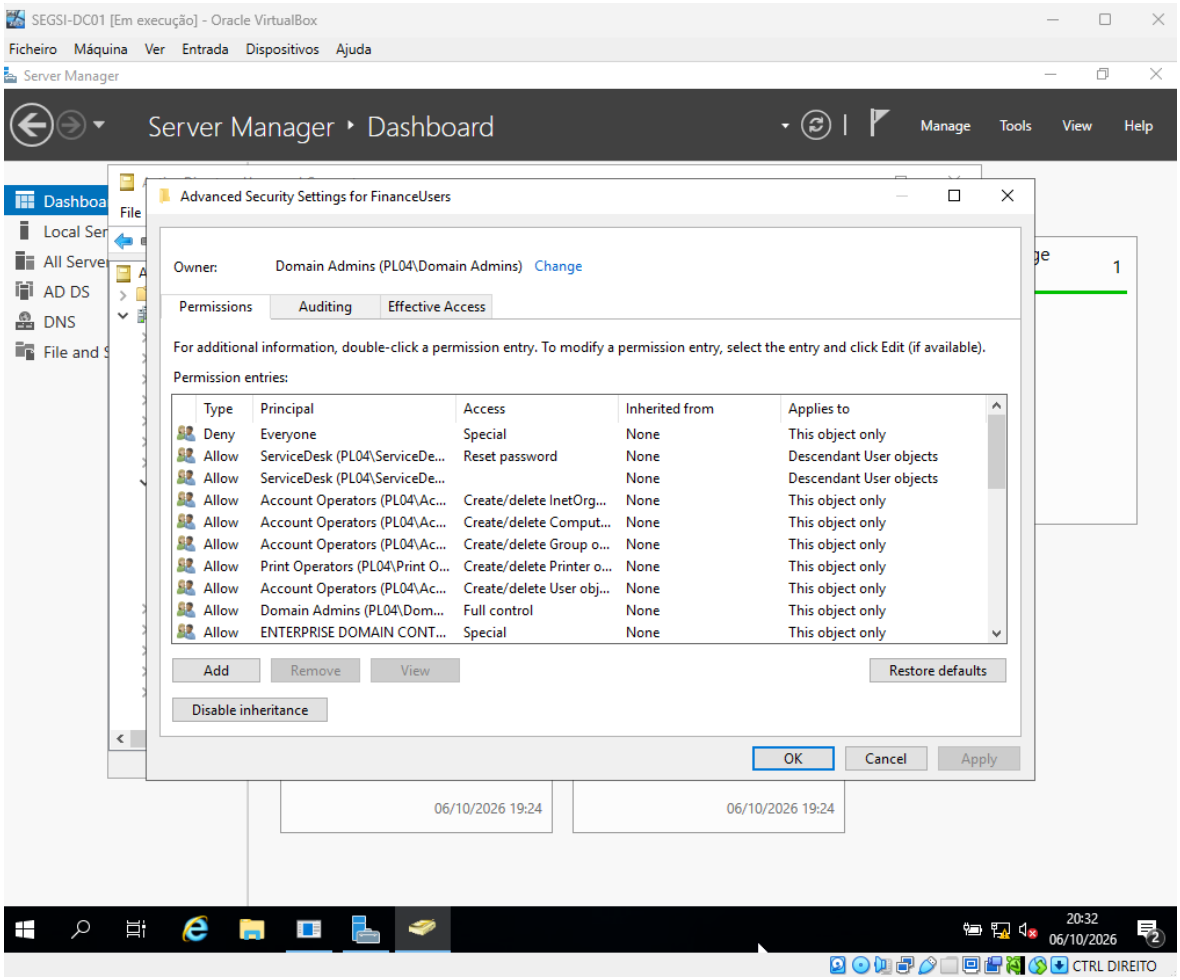


Figure 54 - Password reset permissions delegation to the Service Desk group

The configuration was tested using an account from the Service Desk group. It was able to reset the password of the Finance user.

6.3 SysAdmin – Management of Domain Admins Membership

The second delegation scenario related to the SysAdmin group. Members of this group received the permission to make changes to the membership of the Domain Admins group.

In contrast to the delegation of the Full Control permission to the Domain Admins object, in this case the permission to change membership of the Domain Admins group was delegated.

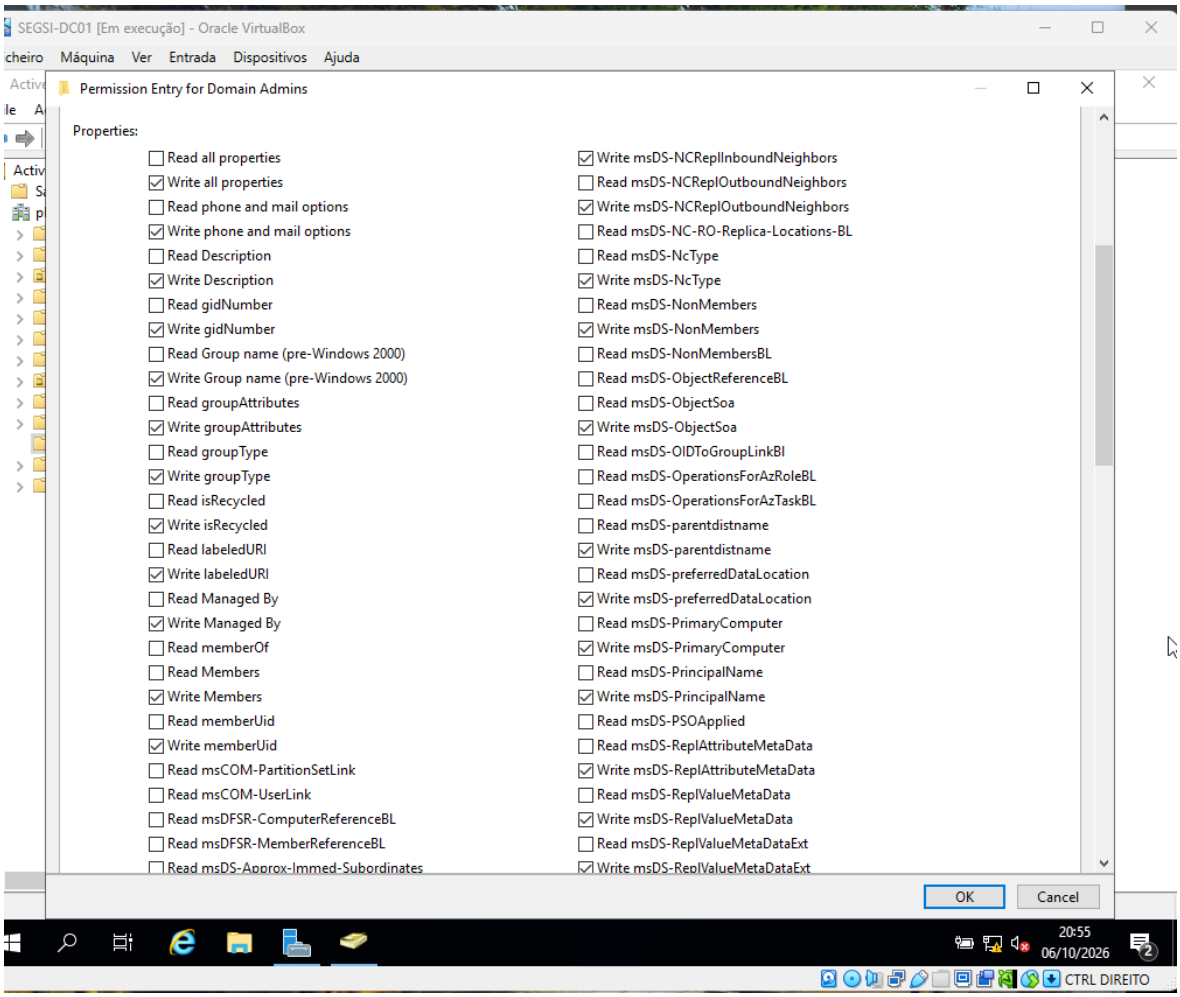


Figure 55 - granting SysAdmin permission over membership of the Domain Admins group

The configuration was validated by changing membership of the Domain Admins group using the SysAdmin account.

This type of delegation is especially critical from the point of view of security. An account with the ability to add an account to the Domain Admins group can actually provide the latter with numerous privileges within the domain.

Therefore, despite the possibility of restricting the DACL permissions for the SysAdmin group to the membership-related operations, such permission still has to be regarded as a high-privilege one.

6.4 HR – Write Personal Information

Scenario three involved the modification of personal data linked with employees' user accounts.

The appropriate permissions were delegated to the HR staff regarding user objects so that the HR staff would be able to administer the appropriate employee information without being able to access user accounts.

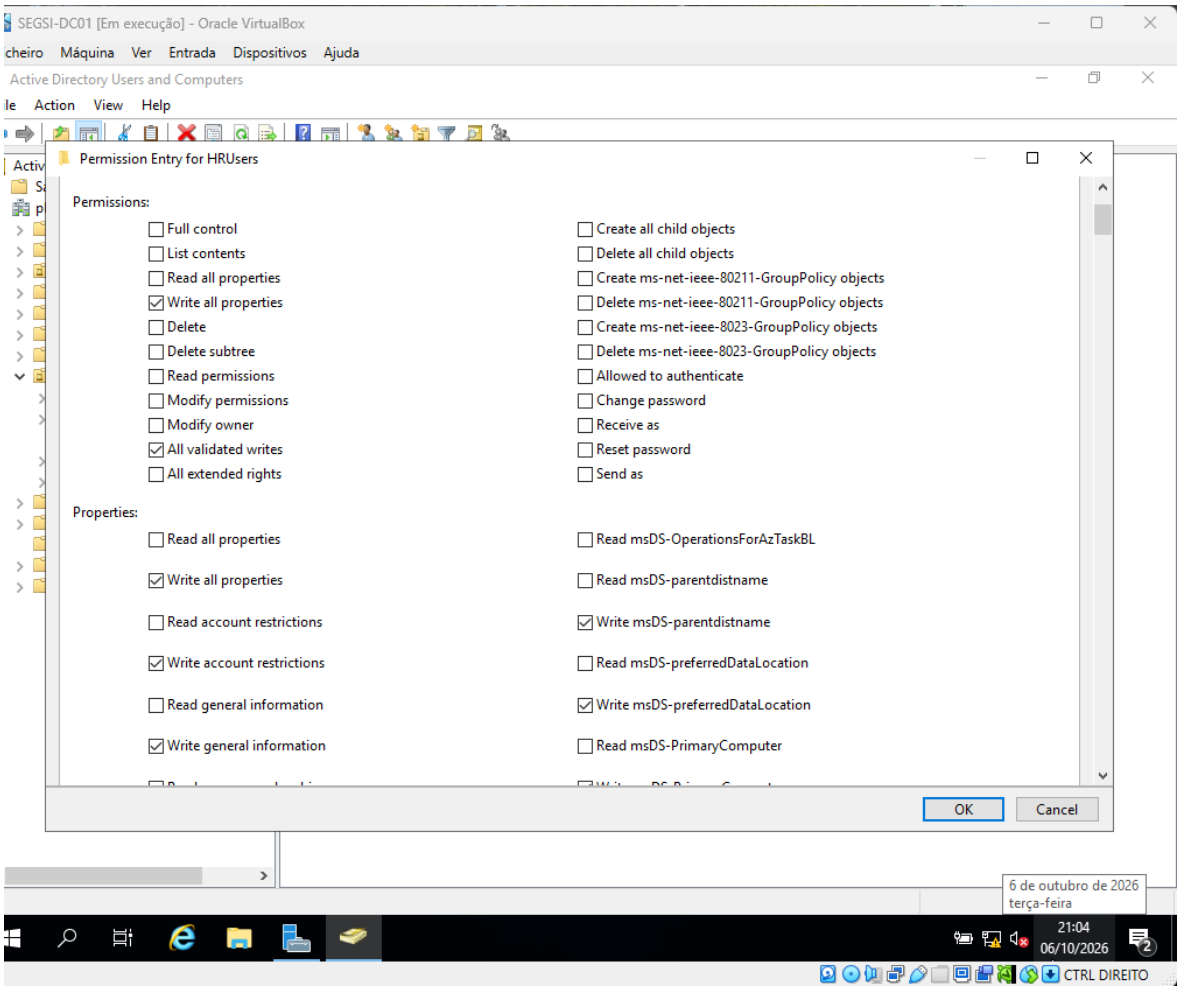


Figure 16 - Delegated permissions allowing HR to modify personal information

This configuration is an example of DACLs separation of responsibilities. The HR staff can administer information related to its responsibilities while all other security operations are beyond its permissions.

In applicable cases, the configuration was tested by changing an allowable attribute by an HR account.

6.5 SysAdmin – Group Membership Management

Another permission to be implemented on the SysAdmin role included management of group memberships.

This permission was granted to the SysAdmin security group instead of individual administrators. This is due to the fact that the administration process becomes more manageable in terms of access control since the administrator's permissions may be administered through the group membership feature.

Using a SysAdmin account, the administrator succeeded in changing the membership of the test group, leaving the delegated permissions related to the SysAdmin security group.

This means that permissions may be administered on the basis of organizational roles instead of individual user-specific ACL entries.

6.6 Limitations of DACL Management at Scale

However, although DACLs allow precise management of permissions for Active Directory objects, their administration can become progressively complicated due to the expanding size of the infrastructure.

In the case of a large organization, a user might get permissions from multiple security groups, and these groups themselves might be nested. The permissions could be either inherited from parent objects or granted to objects individually. It becomes thus quite difficult to trace the source of permissions a user enjoys.

Another issue that might arise would be the growing number of Access Control Entries (ACEs). A lot of exceptions and individual permissions will inevitably complicate the authorization scheme.

Furthermore, there is always a possibility of permission accumulation. For instance, in the case of reassignment of an employee to another position, some permissions and group memberships assigned earlier could stay unchanged.

Thus, in large environments direct assignment of permissions to users should be avoided, and permissions should be assigned based on predefined roles.

Therefore, a proper solution should comprise:

- Role-based security groups;

- Delegation standardization;

- Group nesting control;

- Regular access review;

- Documentation of privileged delegation;

- Removal of redundant permissions and group memberships.

6.7 Additional Security Controls

The use of delegation of administrative activities entails increased security vulnerabilities since any rogue or corrupted account will have access to legitimate privileges. This is why it is important to use DACL configurations along with preventive and detective controls.

Principle of least privilege

Each user or security group shall get the minimum set of permissions required to accomplish their tasks.

Auditing

Active Directory operations related to security need to be audited.

Specifically:

- resetting passwords;

- changes in the group membership;

- modifying privileged groups;

- changes in the directory objects;

- changes in permissions and DACLs;

- attempts of performing the privileged operations shall fail.

This control is particularly important since the previous PL03 includes the requirement to ensure that auditing is correctly configured in Active Directory.

Monitoring and alerting

Audit data not only should be collected but also monitored.

For example, adding a user to: Domain Admins, is a very critical task which can trigger an alert.

Monitoring systems help to identify and correlate such events.

Stronger Authentication

Administrative privileges must rely on more robust authentication techniques. Administrative credentials must also be separate from those used in regular operations.

Periodic Access Review

Periodic group membership and delegated permission review will be required to determine whether individuals need to maintain access.

This combination of measures helps mitigate the risk of abuse of such delegated access.

6.8 Excluding One User from a Group Permission

The last requirement deals with the situation when a user is a member of a group and should not have one of the permissions granted to this group. For this exercise, consider the scenario in relation to effective permissions.

Typically, a user gains permissions granted to the security groups the user is a member of.

If a particular user has to be excluded from receiving a particular permission, an ACE can be explicitly added to the DACL for this purpose in order to deny this particular operation.

Then the Effective Access feature can be applied to determine the effective permissions for this user, taking into account the permissions acquired through being a member of groups as well as applicable ACEs for the account.

While an explicit Deny ACE can be used to accomplish this task, it should be applied with caution.

An excessive number of exceptions would complicate the access control model.

6.9 Summary

This exercise illustrated the application of DACLs in Active Directory for fine-grained delegation of administration duties. As opposed to assigning full administrative privileges, the exercise proved that permissions could be assigned in relation to different security groups that corresponded to the responsibilities of Service Desk, HR and SysAdmin staff members.

Through this process, the implementation showed that the Service Desk staff could be allowed to undertake password management tasks while HR staff could have access to employee information, and SysAdmin staff would have group management responsibilities.

Security aspects relating to delegation were also illustrated where the possibility to change highly privileged groups such as Domain Admins was considered an important capability even when the DACL had few permissions to start with.

Authorization through effective permission was found to depend on group membership, inheritance of permission and exceptions among others. Despite the wide array of capabilities provided by DACLs, permission combination may prove difficult to manage in large organizations.

In view of this, Active Directory delegation should be based on least privilege principle, security groups based on roles, auditing and regular reviews of access rights.

7 Conclusions

In conclusion, this assignment was an opportunity to use theoretical concepts of security in practical situations in relation to networking and system administration.

Using Wireshark, it was possible to study various types of network protocols, see how the systems operate and identify security problems, including the leaking of passwords, unsecured communication, and information leakage. It was also important to differentiate between what is observable and what may be considered a security problem.

Practical tasks showed that correct permissions management and administrative privileges play an important role. This issue was illustrated by the Active Directory tasks, in which access control and delegation allow assigning particular responsibilities without unnecessary access rights.

As a result, it became clear that the combination of secured protocols, adequate access control and monitoring are important for system and network security.

8 References

Technical sources accessed on 16 October 2026. The references explain concepts and tool interpretation; experimental results are documented in the laboratory figures.

[1] Microsoft. Kerberos authentication overview in Windows Server.

https://learn.microsoft.com/en-us/windows-server/security/kerberos/kerberos-authentication-overview

[2] Rowe, D. BadBlood. Project repository and documentation.

https://github.com/davidprowe/BadBlood

[3] SpecterOps. BloodHound Community Edition Custom Installation.

https://bloodhound.specterops.io/get-started/custom-installation

[4] Neo4j. Connect to a Neo4j DBMS. Neo4j Browser.

https://neo4j.com/docs/browser/legacy/operations/dbms-connection/

[5] SpecterOps. MemberOf. BloodHound Edges.

https://bloodhound.specterops.io/resources/edges/member-of

[6] SpecterOps. AdminTo. BloodHound Edges.

https://bloodhound.specterops.io/resources/edges/admin-to

[7] HackTricks. Active Directory Methodology.

https://book.hacktricks.wiki/es/windows-hardening/active-directory-methodology/index.html

Exercise source: Exercise 1 Attacks on Active Directory Kerberos, exercise sheet image. Figure sources: laboratory screenshots identified in their respective captions